

555.5

Alerting and Detection Engineering Pipelines

Licensed To: Arvind Pariti <paritiarvind@gmail_com> April 13, 2026



PLEASE READ THE TERMS AND CONDITIONS OF THIS COURSEWARE LICENSE AGREEMENT ("CLA") CAREFULLY BEFORE USING ANY OF THE COURSEWARE (DEFINED BELOW) ASSOCIATED WITH THE SANS INSTITUTE COURSE. THIS IS A LEGAL AND ENFORCEABLE CONTRACT BETWEEN YOU (THE "USER") AND THE ESCAL INSTITUTE OF ADVANCED TECHNOLOGIES, INC. /DBA SANS INSTITUTE ("SANS INSTITUTE") FOR THE COURSEWARE. BY ACCESSING THE COURSEWARE, USER AGREES TO BE BOUND BY THE TERMS OF THIS CLA.

With this CLA, SANS Institute hereby grants User a personal, non-exclusive license to use the Courseware subject to the terms of this CLA. Courseware means all printed materials, including course books and lab workbooks, slides or notes, as well as any digital or other media, audio and video recordings, virtual machines, software, technology, or data sets distributed by SANS Institute to User for use in the SANS Institute course associated with the Courseware. User agrees that the CLA is the complete and exclusive statement of agreement between SANS Institute and User and that this CLA supersedes any oral or written proposal, agreement or other communication relating to the subject matter of this CLA.

BY ACCESSING THE COURSEWARE, USER AGREES TO BE BOUND BY THE TERMS OF THIS CLA. USER FURTHER AGREES THAT ANY BREACH OF THE TERMS OF THIS CLA MAY CAUSE IRREPARABLE HARM AND SIGNIFICANT INJURY TO SANS INSTITUTE, AND THAT SANS INSTITUTE MAY ENFORCE THESE PROVISIONS BY INJUNCTION (WITHOUT THE NECESSITY OF POSTING BOND), SPECIFIC PERFORMANCE, OR OTHER EQUITABLE RELIEF.

If User does not agree to the terms of this CLA, User should not access the Courseware. User may return the Courseware to SANS Institute for a refund, if applicable.

User may not copy, reproduce, re-publish, distribute, display, modify or create derivative works based upon all or any portion of the Courseware, in any medium, whether printed, electronic or otherwise, for any purpose, without the express prior written consent of SANS Institute. User may not sell, rent, lease, trade, share, or otherwise transfer the Courseware in any way, shape, or form to any person or entity without the express written consent of SANS Institute. Additionally, User may not upload, submit, or otherwise transmit Courseware to any artificial intelligence system, platform, or service for any purpose, regardless of whether the intended use is commercial, educational, or personal, without the express written consent of SANS Institute. User agrees that the failure to abide by this provision would cause irreparable harm to SANS Institute that is impossible to quantify. User therefore agrees to a base liquidated damages amount of \$5000.00 USD per item of Courseware infringed upon or fraction thereof. In addition, the base liquidated damages amount shall be doubled for any Courseware less than a year old as a reasonable estimation of the anticipated or actual harm caused by User's breach of the CLA. Both parties acknowledge and agree that the stipulated amount of liquidated damages is not intended as a penalty, but as a reasonable estimate of damages suffered by SANS Institute due to User's breach of the CLA.

If any provision of this CLA is declared unenforceable in any jurisdiction, then such provision shall be deemed to be severable from this CLA and shall not affect the remainder thereof. A written amendment or addendum to this CLA that is executed by SANS Institute and User may accompany this Courseware.

SANS Institute may suspend and/or terminate User's access to and require immediate return of any Courseware in connection with any (i) material breaches or material violation of this CLA or general terms and conditions of use agreed to by User, (ii) technical or security issues or problems caused by User that materially impact the business operations of SANS Institute or other SANS Institute customers, or (iii) requests by law enforcement or government agencies.

SANS Institute acknowledges that any and all software and/or tools, graphics, images, tables, charts or graphs presented in this Courseware are the sole property of their respective trademark/registered/copyright owners, including:

The Apple® logo and any names of Apple products displayed or discussed in this book are registered trademarks of Apple, Inc.

PMP® and PMBOK® are registered trademarks of PMI.

SOF-ELK® is a registered trademark of Lewes Technology Consulting, LLC. Used with permission.

SIFT® is a registered trademark of Harbingers, LLC. Used with permission.

VMware Workstation Pro®, VMWare Workstation Player®, VMWare Fusion®, and VMware Fusion Pro® are registered trademarks of VMware, Inc. Used with permission.

Governing Law: This CLA shall be governed by the laws of the State of Maryland, USA.

Courseware licensed to User under this CLA may be subject to export laws and regulations of the United States of America and other jurisdictions. User warrants he or she is not listed (i) on any sanction programs list maintained by the U.S. Office of Foreign Assets Control within the U.S. Treasury Department ("OFAC"), or (ii) denied party list maintained by the U.S. Bureau of Industry and Security within the U.S. Department of Commerce ("BIS"). User agrees to not allow access to any Courseware to any person or entity in a U.S. embargoed country or in violation of a U.S. export control law or regulation. User agrees to cooperate with SANS Institute as necessary for SANS Institute to comply with export requirements and recordkeeping required by OFAC, BIS or other governmental agency.

All reference links are operational in the browser-based delivery of the electronic workbook.

Licensed To: Arvind Pariti <paritiarvind@gmail_com> April 13, 2026 SEC555_5_K02_01

Alerting and Detection Engineering Pipelines

DETECTION ENGINEERING AND SIEM ANALYTICS

© 2025 SANS INSTITUTE | ALL RIGHTS RESERVED

K02_01

This area is intentionally left blank.

Table of Contents

SIEM Alerting and Analysis	3
Lab 5.1: Identify Log Gaps and Compare with Sigma Coverage	38
Post-Mortem Analysis and Detection Engineering Pipelines	39
Lab 5.2: Using VirusTotal for Malware Detection and Removal	68
Contacts and Resources	69

This area is intentionally left blank.

Course Roadmap

Section 1: Detection Engineering and SIEM Architecture

Section 2: Network and Endpoint Analysis

Section 3: Asset Discovery, Baselines, and UEBA

Section 4: Cloud Logging and Monitoring

Section 5: Alerting and Detection Engineering Pipelines



- SIEM Alerting and Analysis
 - ☐ Lab 5.1: Identify Log Gaps and Compare with Sigma Coverage
- Post-Mortem Analysis and Detection Engineering Pipelines
 - ☐ Lab 5.2: Using VirusTotal for Malware Detection and Removal

This area is intentionally left blank.

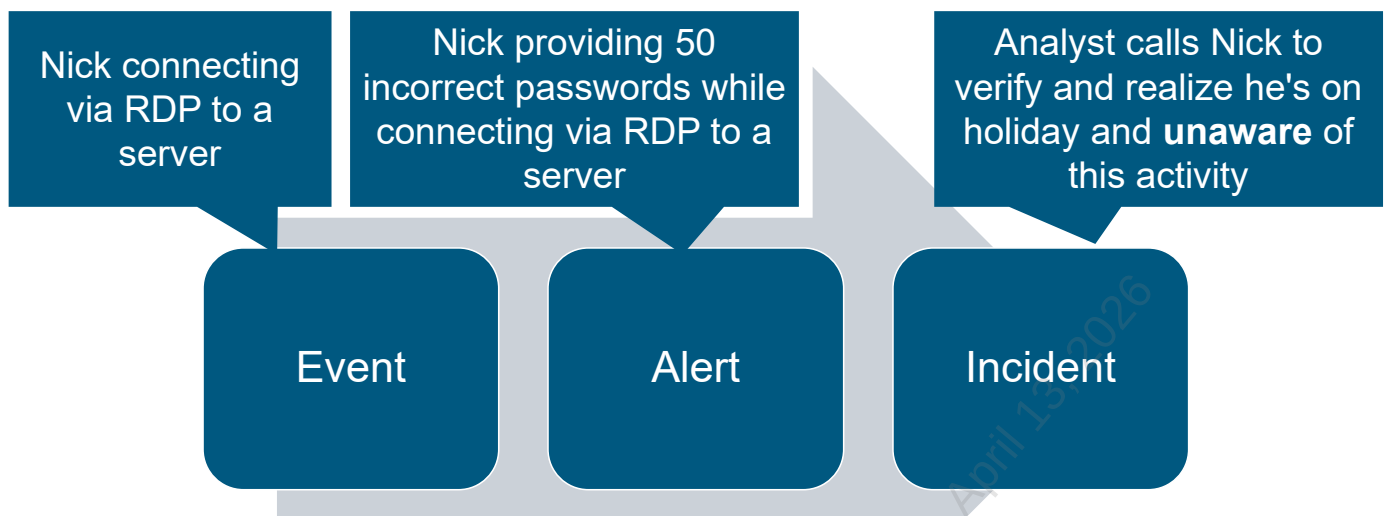
Module Objectives



The student will gain an understanding of best practices regarding alert creation, the advantages of centralizing alerts, and how to perform analysis.

This area is intentionally left blank.

Some Definitions



When dealing with security incidents all the time, the lines between events of interest, alerts, and actual incidents can get blurry.

Event (also known as an event of interest): NIST SP 800-61¹ (Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile) defines an event of interest as "any observable occurrence that involves computing assets, including physical and virtual platforms, networks, services, and cloud environments."

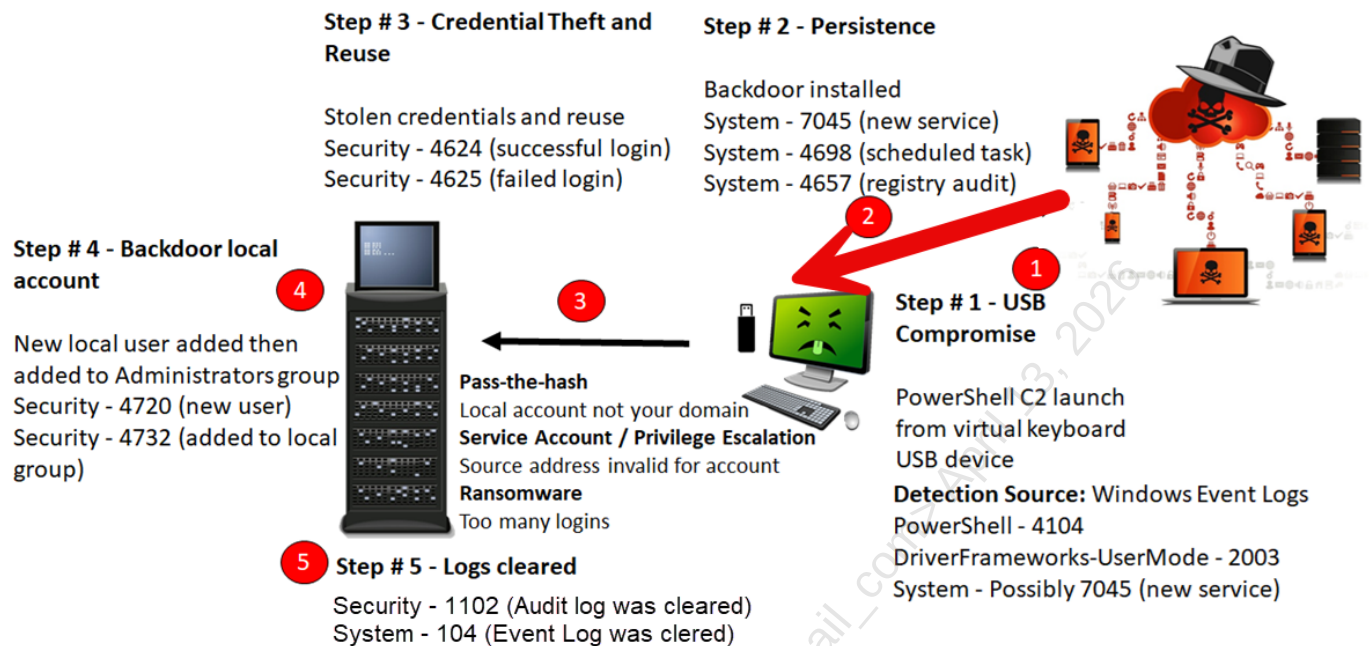
Alert: *Potentially* unwanted or unauthorized event. This really means you don't know. You need to dig into this activity in more detail to understand if it's actually malicious or not. The only thing you see at this point is an alert triggering, meaning some type of security tool or detection rule finds this to be something you should look further into.

Incident: NIST SP 800-61² defines an incident as "an occurrence that actually or imminently jeopardizes, without lawful authority, the integrity, confidentiality, or availability of information or an information system; or constitutes a violation or imminent threat of violation of law, security policies, security procedures, or acceptable use policies."

The key takeaway from the above definitions is that all incidents start as events of interest (which may transpire to be alerts at some point). However, not every event of interest constitutes an actual incident.

1. <https://sec555.com/n7z51>
2. <https://sec555.com/n7z51>

The SIEM Differentiator



This page represents the fundamentals of security monitoring with a SIEM. The example given is a compromise via a USB drive, which then starts a persistent backdoor shell to an adversary. From there, the attacker steals credentials and pivots to additional boxes. Once on the other systems, backdoor accounts are created to simply access. Finally, the attacker's end goal is achieved, and logs are cleared to hide any evidence of their presence.

In this scenario, there are multiple methods to detect every step the attacker takes. A digital trail is paved, and if an organization has a single rule that would identify these steps before the adversary moves too deep into the environment, then the organization would win.

The problem is that SIEM tools do not natively have custom rules that work with minimal effort out of the box.

The challenge is twofold:

Someone has to know what to look for, and then the SIEM needs to be told how to look for that activity. (Welcome to detection engineering. :))

SIEM Is a Security Enabler

SIEM is a driving force for enabling security

Can centralize alerts from other systems

Can generate alerts using built-in rulesets

Can generate custom alerts (requires use cases and setup)

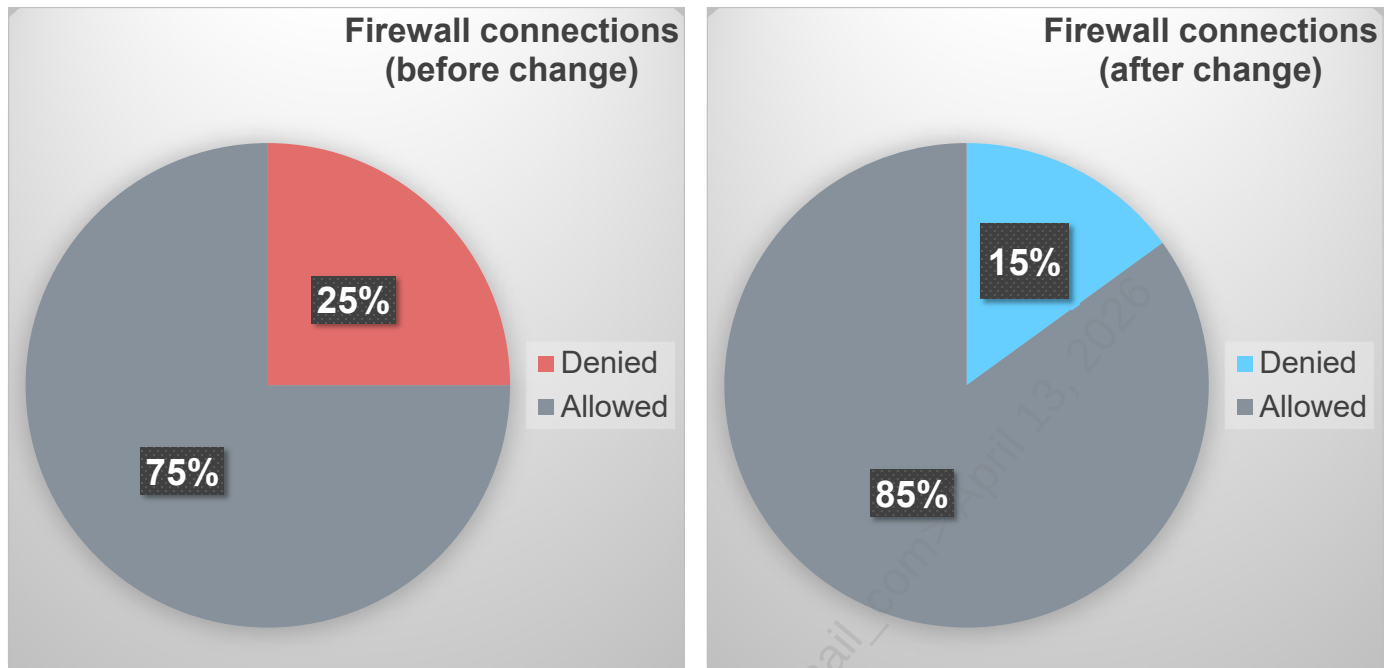
Centralized logging with custom alert generation creates new opportunities

Can automate and alert on almost anything

SIEM solutions are unique in their capability of ingesting massive amounts of logs and then applying automatic correlation and alerts. Typically, each product comes with its own pre-built rules. These rules tend to have varying levels of success as they are written to apply to any company rather than being tailored to one. For instance, when the SIEM vendor develops rules to address client needs, they think wide-scale big picture. However, their logic doesn't necessarily apply in your environment. Even if they cover the bulk of environments, what happens when you are in healthcare, automotive, industrial control space, and similar sectors? Those are so niche that it would be very unlikely for standard SIEM content to be developed and truly be able to match your needs. However, that is why it's so vital to have your own detection engineering team; to empower the SIEM tool to shine.

Tailoring rules specific to your organization is where the value can really come out of a SIEM. The use cases for building alerts are limited mainly to your imagination (within reason). It mostly boils down to you creating the appropriate lab infrastructure to simulate attacks that you expect to see in your environment and creating the related content to detect them.

Case Study: Monitor Changes for Failure at the SIEM



At first glance, you might be thinking, "What do these firewall change images have to do with a SIEM or alerting?"

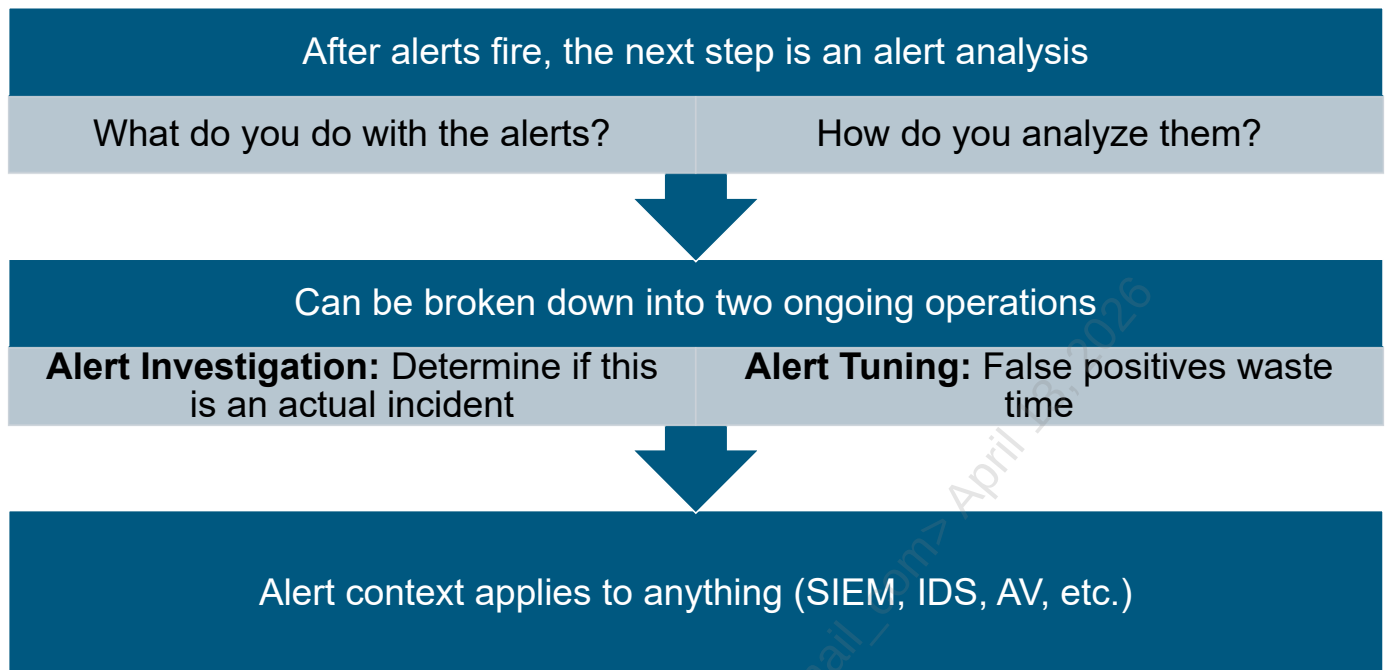
This page shows an example of using a SIEM for change impact monitoring.

On the left is a graph showing the percentage of allowed connections vs. blocked connections on a firewall. The picture on the right represents what the percentages look like after a change has been made at the firewall.

In this case, there is a decrease from 25% of connections being blocked to 15%. This is a large increase in allowed connections. It is possible that a recent firewall rule is too open. While this type of data seems unrelated to a SIEM, this is a possible use case for generating an alert.

A SIEM is perfectly capable of monitoring the ratio of allowed vs. blocked connections on a firewall and alerting if a deviation is observed larger than a specific threshold.

Addressing Alerts



When an alert is present, what should come after it?

First of all, an alert can match the following outcomes:

- **True positive:** There's an actual attack happening, and the alert fires to denote that.
- **True negative:** There's no attack taking place, so there's no alert to be raised.
- **False positive:** There's no attack, but an alert is raised falsely stating there's an attack. You should treat this as an opportunity to improve. Never leave false positive triggers there and allow security personnel to say, "Ah, it's John's or Sarah's machine. Typical false positive". Any false positive alert should indicate an opportunity to perform tuning to avoid a recurrence.
- **False negative:** There's an attack taking place, but no alert is raised to depict that. Common reason? There's no detection content to reflect the attack. For example, the attacker is performing SQL injection, but you currently have no SQL injection content to fire an alert.

Alert Thresholds

Alert engines are more robust than standard searches

- Have extra capabilities specific to managing alerts

Such as:

- **Aggregating alerts** together: 1 alert instead of 1,000
 - Will delay receiving alert until time constraints met
- Setting alert **thresholds** to minimize volume of alerts
- **Minimizing alerts**, so they do not repetitively trigger
- **Alert prioritization**

An alert engine is designed for complex queries and advanced functionality. Some of this functionality includes preventing a flood of alerts. This can be performed by combining repetitive alerts into one or by limiting the number of alerts that can be generated within a specific time frame.

Consider an alert is set up to monitor for service account use not sourcing from a specific system (such as a vulnerability scanner). This is intended to alert on any occurrence because, under normal conditions, there should be zero occurrences of that account used outside the expected context. Yet, if an adversary were to gain access to and start using this account, they may use it to access hundreds or thousands of systems within minutes. By default, this would generate hundreds or thousands of alerts. Instead of unleashing this flood, an alert engine can limit the number of alerts generated, such as only generating 5 alerts within an hour, or it can aggregate all matching occurrences within a 10-minute window into a single alert. Typically, this would show as something like 1,000 unauthorized privilege uses for the service account detected.

Limiting the number of alerts the tool generates has two significant advantages:

- It ensures the SIEM tool is operational and isn't overwhelmed by the amount of generated alerts.
- It facilitates investigations because the security team doesn't have to review 1,000 alerts.

Alert Investigations



Investigating alerts should include documentation

- May start as notes but should grow over time
- Some folks are old school and keep their notes on paper. Does that work?
- Should they only be recorded digitally?
- Maturity level and business type dictate requirements

Documentation may often look boring and tedious, but think about how life-saving it can be.

You have a SOC working around the clock over three different locations. When one shift finishes, the next one picks up. How would they be able to continue investigating if you don't have proper notes included in every case?

But you need to strike a balance and not make it overwhelming. Having little documentation is clearly not enough, and documenting absolutely everything can be too much. The right balance is hard to find as it differs from organization to organization.

When it comes to case management, maximum maturity is more about rightsizing the process. This could mean that maximum maturity may involve less documentation, or it could mean more documentation and process enhancements, even possible automations. Remember about finding a balance? Ultimately, you have to think, "If I were an analyst working on this case, with the existing notes, would I be able to investigate efficiently?"

There's a saying in incident handling: "If you are going too fast to take notes, stop. You're going too fast." Also, even if you are the only person working on a case, how are you going to remember why a certain action was taken if management asks in six months from now?

No matter if you are thinking about continuity of operations or justifying actions taken or being compliant during investigations, or a combination of the above, note taking is your friend.

Ideally, you want that to be done in a way that notes can't be manipulated. Most case management tools today offer options to ensure the integrity of notes and artifacts you upload to cases, so that they can't be altered later on, which could lead to compromising the investigation.

Timeline of Alerts

Helpful for default view to be time-based

- Alert name, connection details, and # of occurrences

The alert queue is often prioritized by a subjective rating

Rule ↕ Q	Source IP ↕ Q	Source Port	Destination IP	Destination Port	Last Occurrence ↕ Q	Count
ET POLICY PE EXE or DLL Windows file download	107.167.7.177	808	10.0.2.15	1,048	03-21 11:04:10.280	2
ET POLICY TLS possible TOR SSL traffic	173.236.34.122	9,001	172.16.253.131	1,982	03-21 11:04:08.065	3
ET POLICY Outbound Multiple Non-SMTP Server Emails	168.131.48.242	1,309	78.47.186.34	25	03-21 11:04:07.416	1
ET TROJAN Possible NetWire RAT Client HeartBeat C2	192.168.133.173	49,162	67.215.4.77	3,369	03-21 11:03:58.083	36
ET TROJAN NetWire RAT Client Check-in 2	192.168.133.173	49,162	67.215.4.77	3,369	03-21 11:03:58.083	49

Host-based alerts may only reflect source IP and alert name

- Failed logins 10.5.55.7 2025-03-21 11:05:57.123 103

A dashboard or view of alerts, typically, is based on a timeline showing the most recent alerts scrolling down to older alerts. Usually, this is accompanied by some basic information such as an alert's name, IP address and ports involved, the priority of the alert, and how many times the alert has triggered. Depending on how an organization is structured, alerts may be handled, for example, by asset SLA or perceived risk. Perceived risk allows an analyst to use their judgment to identify the highest risk alerts to investigate first.

In this slide, five alerts are shown; yet ET TROJAN NetWire RAT Client Check-in 2 is identified as the highest risk alert to be investigated. The logic behind this can be found below.

- ET POLICY PE EXE or DLL Windows file download:** Indicates an EXE or DLL download. This is a common event. Even when properly filtered, it typically requires validation of the EXE or DLL downloaded.
- ET POLICY TLS possible TOR SSL traffic:** If this is not a false positive, it is TOR traffic. Someone or something is trying to remain anonymous. This could be C2, or in many instances, it is internal users breaking company policies. Needs investigation, but not a top priority, given other alerts.
- ET POLICY Outbound Multiple Non-SMTP Server Emails:** This rule is looking for emails that are not from authorized email servers. Should be investigated, but could be a new server or a desktop application legitimately sending an email without a new change request submitted.
- ET TROJAN Possible NetWire RAT Client HeartBeat C2:** Indicates that a machine is likely compromised and checking in with a C2 server using NetWire. This rule means, effectively, the same as ET TROJAN NetWire RAT Client Check-in 2.
- ET TROJAN NetWire RAT Client Check-in 2:** Indicates that a machine is likely compromised and is checking in with a C2 server using NetWire. This rule means, effectively, the same as ET TROJAN Possible NetWire RAT Client HeartBeat C2.

High Count Alerts

Rule ↕ Q	SID ↕ Q	Rule Type ↕ Q	Count ↕
ET POLICY RDP connection confirm	2001330	Emerging Threats	103,985
ET POLICY Dropbox DNS Lookup - Possible Offsite File Backup in Use	2020565	Emerging Threats	238
ET TROJAN ABUSE.CH Ransomware Domain Detected (TorrentLocker Payment)	2023706	Emerging Threats	12

An alert that fires constantly is indicative of:

- Poorly written rule
- Reconnaissance or anomaly rule that is noise in your environment
- Frequent network activity to or from an attacker

Likely one of the first two

Many high-profile breaches involve companies that had alerts relating to the compromise. The problem: Too many alerts to handle. At some point, tough decisions need to be made, and some alerts may not make the cut. The point is that not all alerts are valid for every organization, and most certainly, not all alerts are created equally. Some provide an extreme certainty that an organization is compromised, and others simply state something like, "I saw RDP connections, and depending on your organization, this may not be allowed by policy."

An easy starting point for tuning is to search for alerts with high repetition. These are most likely false positives or alerts that do not matter in your organization. Yes, it could be constant alerts from attacker activity, but that is usually a bit more obvious.

The image on this page shows 103,985 alerts relating to RDP connections. If RDP is not allowed at all, then these are all true positives. If RDP is allowed internally to servers and these alerts pertain to that, then the rule could be modified or disabled.

For instance, if RDP to workstations or external sources is unauthorized, then the rule should be configured to ignore internal server subnets.

Alternatively, if the sensor generating the alert can only see incoming server connections, the rule could be disabled.

Next on the list is Dropbox alerts with a count of 238. This is still a high count, but could be from a single box regularly synchronizing with Dropbox.

So, why does the same alert trigger all the time? Is it really nothing, or could it be something that has been missed before, or maybe there's some context missing around the user or system in question, or both?

In short, be certain that when you are tuning alerts, don't go to the other end of the spectrum and tune to the extent of missing visibility. A good solution is to do a gradual tuning where you reduce the thresholds gradually, without going big bang in one go.

Auto-Categorization

Some rules are expected to be noisy

- ET SCAN Potential SSH Scan from external
- Question is, do you care?
- An analyst **should not** be investigating every port scan

Auto categorizing these alerts can be useful

- Can be used in management reports
- Can also be applied to specific policy violation alerts
 - Specifically, those over which you have no authority

The problem is that you may not want to filter out certain alerts. For example, ET SCAN Potential SSH Scan likely means someone is port scanning your systems over port 22. This is bound to happen almost every day from internet sources. The question then becomes, do you care? An analyst does not have time to investigate every port scan from the internet. If the rule triggered internally, that would be different.

One way to handle this is to filter out external scans and other noisy alerts or to automatically categorize the alerts. Automatic categorization can tag and route alerts so that an analyst can search them later, but they are not in the queue for alerts to investigate. This allows the data to be used for reporting and investigating purposes without wasting a lot of time trying to navigate through the alerts.

Custom Alerts

Multiple options available to **generate custom alerts** or integrate with MITRE ATT&CK or other frameworks

- Single log matching certain criteria (**deny lists**)
- Any log not matching certain criteria (**allow lists**)
- X events in Y time frame (**frequency**)
- High or low fluctuations in log counts (**spike/flatline**)
- Aggregation thresholds (example: **change monitoring**)

Can be combined and can trigger actions

The most common place for generating alerts within a SIEM is an alert engine. This page represents some of the more common alert triggers used:

- **Alert on match:** This will perform a query and alert for anything matching the query. For example, if Event ID is 123, then alert.
- **Alert on match excluding known/authorized criteria:** The reverse logic can be used for allow lists. For example, alert if the Event ID is not 123.
- **Repetitive matches:** This will trigger an alert when there are a certain number of matches within a specific time. For example, 50 failed logins in 1 minute.
- **High fluctuation:** This monitors the count of logs matching a query within a certain time period. If the number of logs increases rapidly within the time period, it will generate an alert—for example, if a Windows system starts to generate 50% more events than normal.
- **Low fluctuation:** This monitors the count of logs matching a query within a certain time period. If the number of logs decreases or stops within the time period, it generates an alert. An example of this would be generating an alert if a Windows server stopped sending over logs.
- **New or changed fields:** This monitors values within certain fields in a query. If they change or have new values never before seen, an alert is generated. This can be used to monitor Windows service events. For example, if a new service is created with the name of steam2, it would generate an event so long as that service has never previously been seen.
- **Aggregation thresholds:** This monitors things such as min, max, average, or count returned by a query. If the returned value deviates from a threshold, it generates an alert. An example of this is the previous change monitoring impact graphs.

Alert Tuning



SIEM contains current and historical alerts.

- Reports can be built to help tune out false positives
- Should be performed on a regular basis



Items to look for:

- High alert counts
- Alerts that need modification
- Alerts that should be auto-categorized



Tuning is an extremely important function of a tactical environment. It is also a skill that evolves over time. What you ultimately want is a manageable number of alerts for investigation. If 1,000 alerts per analyst are generated each day, then they will fail.

One of the things you need to remember is that when alerts fire, you should take reasonable steps to investigate what happened and try to ascertain if this is an actual incident. However, if you're not certain or if you are reaching the limit of your skills and/or experience, it's time to escalate to another level of security analyst. It's a common mistake to have an optimistic or overzealous investigator taking too long to ask for help, giving the attacker more time to gain a foothold and cause more damage.

Existing Alert Modification

Account for triggered alerts caused by very few systems

- Could be a misconfigured or non-RFC application
- Could be an approved one-off policy exception

Rather than disabling alerts, filter out or classify exceptions

- Dropbox may be allowed for 10.0.1.2 but no one else
- Filter 10.0.1.2 and then monitor new Dropbox alerts

Rule ↕ Q	IP ↕ Q	Count ↕
ET TROJAN Ransomware/Cerber Onion Domain Lookup	10.0.0.10	390
ET POLICY Dropbox DNS Lookup - Possible Offsite File Backup in Use	10.0.1.2	324

Rather than disabling a rule like Dropbox, an organization could modify it so that it does not alert against authorized exceptions. This could involve rewriting the alert or filtering out certain alerts at the SIEM. This can be helpful when an organization policy states something is not allowed but has a handful of exceptions, or if an alert is only triggering against a server or application that is constantly generating false positives. Rather than disabling the alert entirely, tune out the root cause of the noise.

Where Do We Tune?

If possible, tuning should be done on the alerting device.

- **IDS/IPS:** Modify or disable rule on IDS/IPS
- **AV:** Disable signature in AV
- **Application Control:** Filter or auto-categorize at SIEM
- **SIEM rule:** Modify or disable rule at SIEM

Alternatively, you can tune at the SIEM for granularity or ease of operations.

- The security system may not support filtering/disabling.

Ideally, tuning should be done at the device generating the alert. For example, if a NIDS is constantly alerting about RDP activity, then the rule should be disabled or modified at the NIDS. There is no point in sending data to the SIEM only to drop it when the NIDS can suppress the alert.

The reason behind this is that it will improve the performance of both the SIEM and whatever other security device is involved. Where an exception should be made is when filtering at the SIEM is significantly easier than dealing with the other device. Some systems do not have filtering capabilities or are so difficult to manage that it seems like a PhD is required. In this case, make a management decision on whether or not to deal with it at the SIEM level.

More Insight

Analysts

Knowledge base

Quality control

False positive reduction

Risk ranking

Escalation to other teams

Management

Metrics and reporting

Service level and operational level agreements

Staff forecasting

Efficiency

Depending on working as an analyst or perhaps as a manager, you might have different motives for documenting alert investigations:

Analysts

- **Knowledge base:** Imagine how awesome it would be if you were an analyst and could see adequate notes in each case you investigate. First of all, if you are a new analyst, this can be the equivalent of a crash course in analysis. Provided, of course, that you are viewing solid investigations. It's like reading a book on investigating incidents.
- **Quality control:** Going over how an investigation was performed can be extremely illuminating, as great effort or possible wrong actions taken and room for improvement. For example, during one of the author's quality reviews, it was uncovered that the analyst in question performed an investigation that was not only incorrect, but it was also on the wrong system. :(
- **False positive reduction:** If you carefully view notes, you can make great cases for improving detections. In fact, you should have a rule. For each incident closed as a false positive, there should be a new (or chained) ticket to detection engineering about fixing the problem.
- **Risk ranking:** Having the added information can better equip you with identifying the appropriate risk categorization for each incident. Something may have been raised as low, but upon additional insight, it's actually high.
- **Escalation to other teams:** When you send a ticket over to another team, it greatly benefits them when you have abundant information. They can get the ball rolling very easily, without wasting time or being puzzled about what has or hasn't been done.

Management

- **Metrics and reporting:** Management can get good insight as to how well case investigations are being performed when there are good notes. For example, if this is a critical incident and it took 10 hours for someone to have a look and escalate to a senior person, that will be bad. Most case management tools support heavy metrics, which are used in automatic reporting and dashboard creation, in order to

signify deviations that should be pursued by operational managers.

- **Service-level and operational-level agreements:** If predefined SLAs (service level agreements) are jeopardized, management should know. This could be both in the case of internal SLAs to the business or external ones to clients. Sometimes, the former get ignored. Do you think it's not important to investigate a staff member issue in comparison to a client? Think again. It's as vital, if not even more, to keep your environment secure so you can, in turn, secure others.
- **Staff forecasting:** If SLAs and performance start dropping, assuming that processes and tools are ironed out, it can be a sign of staff fatigue. Getting related metrics and looking at this closely can help forecast when additional people are required, either on a permanent or a temporary basis.
- **Efficiency:** This is an attempt to measure how optimally investigations are being performed and ultimately what tweaks can be done in people, training, processes, and tools to improve operations.

Managing Alert Data



Before applying use cases, data needs to be collected

- First, need to identify where alerts will be managed



SIEM alert/case management system (maturing)

- Work alerts out of SIEM
- Easily pull in search data or mark it for retention



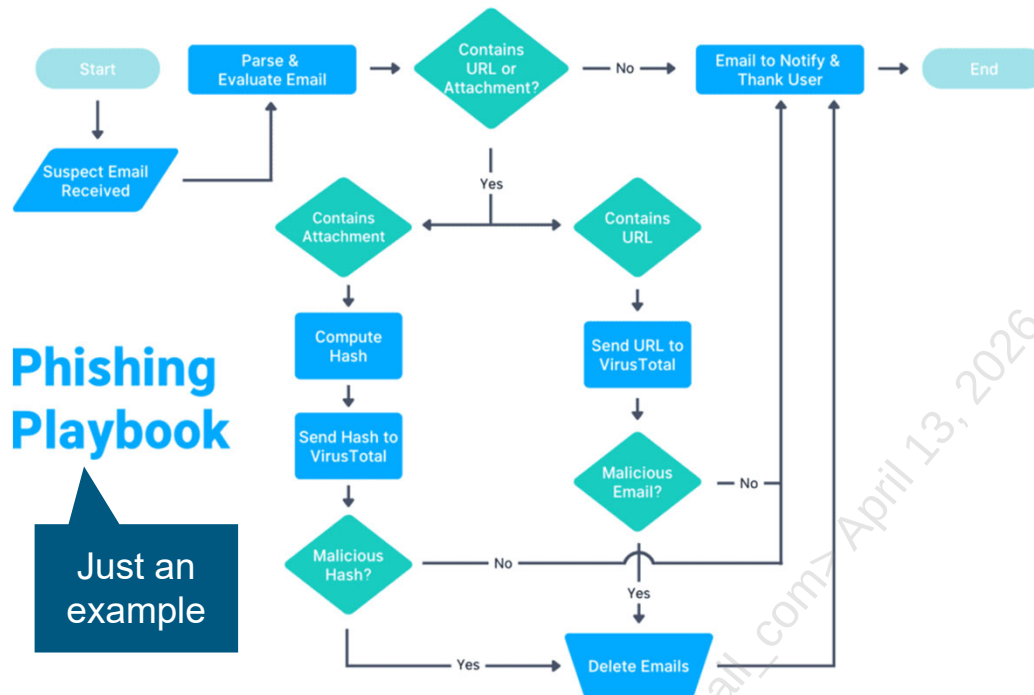
Ticketing system (commercial vs open-source)

- Custom workflows and fields
- Auditors like "single source" of alerts/incidents

In a perfect world, case management would be handled in the SIEM. The SIEM would receive all alerts and provide all the capabilities needed to work an alert. While the SIEM space is maturing and providing integrated case management, many organizations seem to be leveraging third-party systems, which help them integrate not only with a SIEM but various other tools, like DLP (data loss prevention), threat intelligence platforms, vulnerability scanners, and more. All these different tools can be pumping information in the form of a ticket. For instance, when you finish a vulnerability scan, you need specific remediation tickets to be created for engineering, networking, and other teams to action them. That's because different teams are responsible for different types of devices. A server remediation would go to IT engineering, but a router vulnerability would go to the network team. You don't require an alert in that case, but rather integrate the information in a ticket, which you can update and track. Remember that sometimes you need to capture and manage information, and that doesn't necessarily mean an alert. Usually, we start via alerts, but not for everything we do.

Ticketing systems are flexible, and there usually is in-house investment (especially if a ticketing system is used by multiple business units in the company) and knowledge to maintain or tune them, and auditors still tend to prefer a single source for alerts and incidents. These are often commercial solutions but may also include free and open-source software. When using a third-party system, an extra step must be included: sending alerts to the third-party system. But as technology progresses, more and more ticketing tools support integration with SIEM and other third-party solutions. Examples and references of specific tools follow later in this module.

Playbooks



A playbook involves certain types of alerts, forcing analysts to follow a step-by-step guide.

In this example, each time a phishing alert is received, the analyst needs to go through the steps in the phishing playbook. The benefits of having playbooks are:

- Have a pre-agreed response on dealing with incidents of certain types. The more mature an environment becomes, the more playbooks are increased.
- Eliminate analytical mistakes by responding to incidents in a uniform way, which has already been signed off. This reduces the possibility of different analysts responding in whatever way they see fit.
- Playbooks offer the basis of automation and a ground for SOAR (Security Orchestration Automation and Response). Some of the steps in playbooks (and in some cases, whole playbooks) can be automated so the analyst doesn't lift a finger. You might be thinking this is the equivalent of a self-driving car, but the reason behind it is to reduce the potential for mistakes, in addition to reducing response time while performing incident handling.
- Playbooks can also integrate with business notifications, if you wish to. For instance, if an alert is marked as a high-severity incident, it may force the CISO to get involved to make business decisions and start communication with other executive members.

If playbooks are enforced, it is recommended to allow an analyst the option of ignoring the playbook. This may be necessary to handle one-off alerts or miscategorized alerts. In either case, the analysts should have to provide a reason for why they deviated from the playbook. **Just dismissing a playbook should never be allowed.**

Image reference:

- <https://swimlane.com/blog/incident-response-playbook>

Use Data for Staff Forecasting

Reporting total alerts over time can forecast staffing needs

- Used by management to keep proper staffing levels

Security is often understaffed—forecasting may be ignored

- Not enough budget
- Executive decision
- Lack of qualified candidates

It can be used differently

- Which alerts need to be cut, to handle current staffing?

Case management data can also be used for staff forecasting. From a management side of things, this can be used to try and establish proper staffing. However, cybersecurity is often an understaffed field. This means you may always be understaffed. If that is the case, this kind of forecasting can be used to level-set the playing field.

This involves taking the number of analysts and the number of alerts and trying to find a way to make it work. Ultimately, this means focusing on removing less important alerts so that analysts are not as bogged down. If you have more alerts than you can handle and you are not going to hire more staff, then you have to make some tough decisions. Basically, it comes down to which alerts you can live without so that analysts have a chance of keeping up.

Automation (e.g., playbooks) greatly helps reduce analyst fatigue. But at the end of the day, you shouldn't be expecting irrational things. Would you want a single analyst to investigate 100 critical incidents a month? Burnout is something that can very easily happen, so you need to watch for early indicators of it. If you have done the best that you can with your tools and processes, and the numbers are still high, there are two solutions:

- Reducing number of alerts
- Increasing number of SOC analysts

Use Data for Staff Training

Back to the first module: "lowest scores are people and process"

- Case management can track strengths and weaknesses

Managing and encouraging people is part of a good process

- Bob is slow and inaccurate when looking at C2 alerts
- Sally is the exact opposite (fast and accurate)

Two opportunities

- Training opportunity for Bob (*possibly* by Sally)
- Can encourage Sally and use her for KB and playbooks

One area commonly overlooked for process enhancements is people. If data is available to track how well or poorly individuals are doing at alert management, it should be used. If an individual is identified as struggling, then you have identified a growth opportunity to help them out. In some cases, extra training may not solve the issue, and the team member may need to switch job duties or be let go. In most cases, training will help them, and future reports will show a direct improvement.

On the flip side, if an individual is doing extremely well, then they should be rewarded and possibly consulted for creating knowledge-based (KB) articles, playbooks, and training opportunities for other staff. If they have a knack for what they are doing, then their process of handling things should be analyzed, shared with the team, or standardized. A word of caution: Being a skilled analyst does not mean an individual is a good instructor. If an individual is team-oriented and skilled, use them to help train other members. If they generally like to do their work and be left alone, do not have them train other members. Doing so can actually hurt more than it can help.

On another point, the author has seen several organizations create what they call focal points. For instance, someone is great at looking at malware-related cases, and they become a focal point for that, spending 90% of their time there. There are three challenges in that approach:

1. What happens if that person isn't available or leaves the company? You are creating a single point of failure that shouldn't exist.
2. The individual dealing with the same alert type all the time will never get a chance to upskill and investigate different incidents. Their performance plateaus, and they aren't able to do anything else.
3. How many team members will be enough for this to work? If you have 20 types of incidents, will you hire 20 different people?

You want the team to be as all-rounded as possible so they can constantly collaborate to strive for improvement, not siloed in individual cases.

Sigma

Writing new rules per SIEM is reinventing the wheel

- Fortunately, **Sigma** exists to fill the gap
- Written by Florian Roth & Thomas Patzke
- High-level **generic language for analytics**
- MISP compatible: Share and store aligned with threat intelligence
- Decouples rule logic from SIEM vendor and field names
- Eliminates SIEM tribal knowledge

Sigma¹ is an open-source project that provides a generic language for writing SIEM rules.² Effectively, it allows organizations to write rules in Sigma format and then convert them with a tool called pySigma,³ which is a Python library that is able to parse and convert rules into queries. This is the successor of the previously used sigma converter (sigmac).

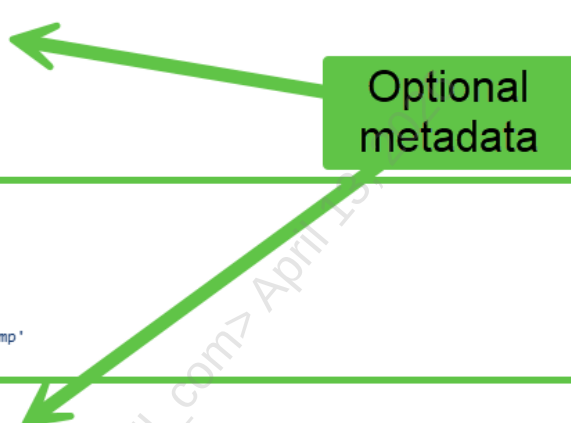
The key advantage here is that rules can become portable and much more likely to be shared. To that effect, the Sigma project has a rules folder that contains many pre-written community rules that also map to MITRE techniques and categories. In the words of the founders, "**Sigma is for log files what Snort is for network traffic and YARA is for files.**" This is incredibly useful in situations where you are porting rules to different ecosystems (possibly using different SIEM tools) or possibly swapping SIEM tools as time goes by. Wouldn't it be a shame for you to have developed a variety of rules throughout the last 5 years you had SIEM X, and now moving to SIEM Y causes you to lose all that work?

Well, you don't have to. As long as you develop in Sigma, your rules can be immortal and just change SIEMs.

1. <https://sec555.com/ldhw3>
2. <https://sec555.com/q6ujn>
3. <https://sec555.com/mrqwe>

Sigma Rule Format

```
1  title: Potential CSharp Streamer RAT Loading .NET Executable Image
2  id: 6f6afac3-8e7a-4e4b-9588-2608ffe08f82
3  status: experimental
4  description: |
5      Detects potential CSharp Streamer RAT loading .NET executable image by using the default file name and path associated with the tool
6  references:
7      - https://thedfirreport.com/2024/06/10/icedid-brings-screenconnect-and-csharp-streamer-to-alphv-ransomware-deployment/#detections
8      - https://cyber.wtf/2023/12/06/the-csharp-streamer-rat/
9  author: Luca Di Bartolomeo
10 date: 2024-06-22
11 tags:
12     - attack.command-and-control
13     - attack.t1219
14     - detection.emerging-threats
15 logsource:
16     category: image_load
17     product: windows
18 detection:
19     selection:
20         ImageLoaded|re: '\\AppData\\Local\\Temp\\dat[0-9A-Z]{4}\\tmp'
21     condition: selection
22 falsepositives:
23     - Unknown
24 level: high
```



Sigma rules are written in YAML format. The Sigma rule on this page is an example of a rule about the CSharp Streamer RAT loading a .NET executable image by using the default file name and path associated with the tool (as also seen in the rule's description). As you can see, each rule has a lot of metadata fields it may contain, but there are only three required fields:

- Title
- Logsource
- Detection

However, it is highly recommended to populate as many as possible, as that allows for ease of readability and customization.

In the above example, the logsource fields denote the category is **image_load** and product is **windows**, which means that Windows logs are **monitored for an executable or DLL being loaded into memory (image_load)**.

The detection logic uses a regex to identify a match when an executable is loaded from a path like `\AppData\Local\Temp\datXXXX.tmp` (where the X characters represent 0–9 or A–Z). Example match: `\AppData\Local\Temp\datA14C.tmp`

Notice that the state of this rule is described as experimental. And at the bottom, where the false positives section is, it states the level is high. You have to be careful when applying rules in production environments to ensure you are comfortable with the type and false positive amount, as that may increase additional overhead. (Rule source: <https://sec555.com/mrqwe>.)

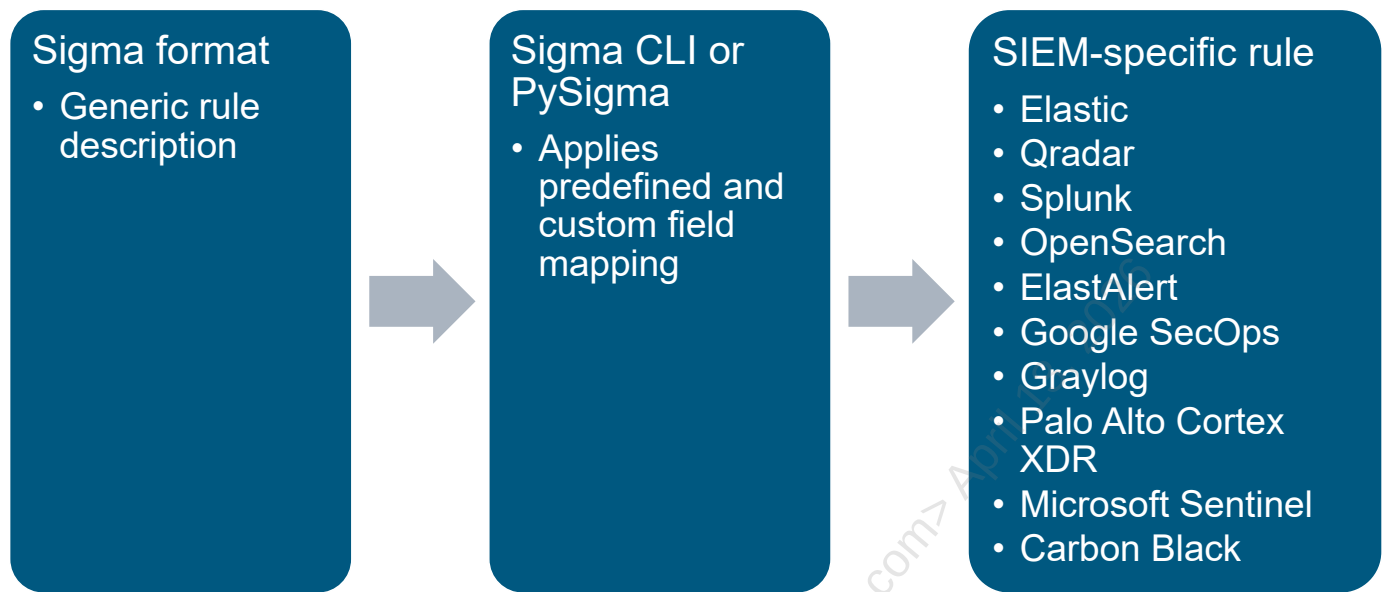
Sigma rules have the following possible statuses:

- **Experimental:** Used to describe a new rule that hasn't been thoroughly tested.
- **Testing:** Limited validation has taken place, but the rule is certainly more stable than an experimental one.

- © SANS Institute 2025
- **Stable:** Widely tested and verified in production.
 - **Deprecated:** The rule shouldn't be used anymore, possibly because a newer rule exists superseding it, the detection method is not up-to-date, or maybe the threat is not relevant anymore.
 - **Unsupported:** The rule isn't maintainable anymore and won't be actively updated. For example, maybe it's related to Windows XP, which is end of life and support, so there's no point in having this rule anymore.

Two other key items to highlight are the references and description fields. Remember that although the creator of the rule may know what it is about, and Sigma is a very high-level descriptive language, making it easily understood, things can get a bit more challenging when there are multiple detection conditions. And you definitely don't want to make security analysts waste time figuring out what this is about. In short, use these fields to provide clarity about what you're trying to detect and how that works so that security personnel can easily identify this and move to the actual events behind the rule, vs. wasting their time trying to find out what the rule actually is about.

Sigma Operation

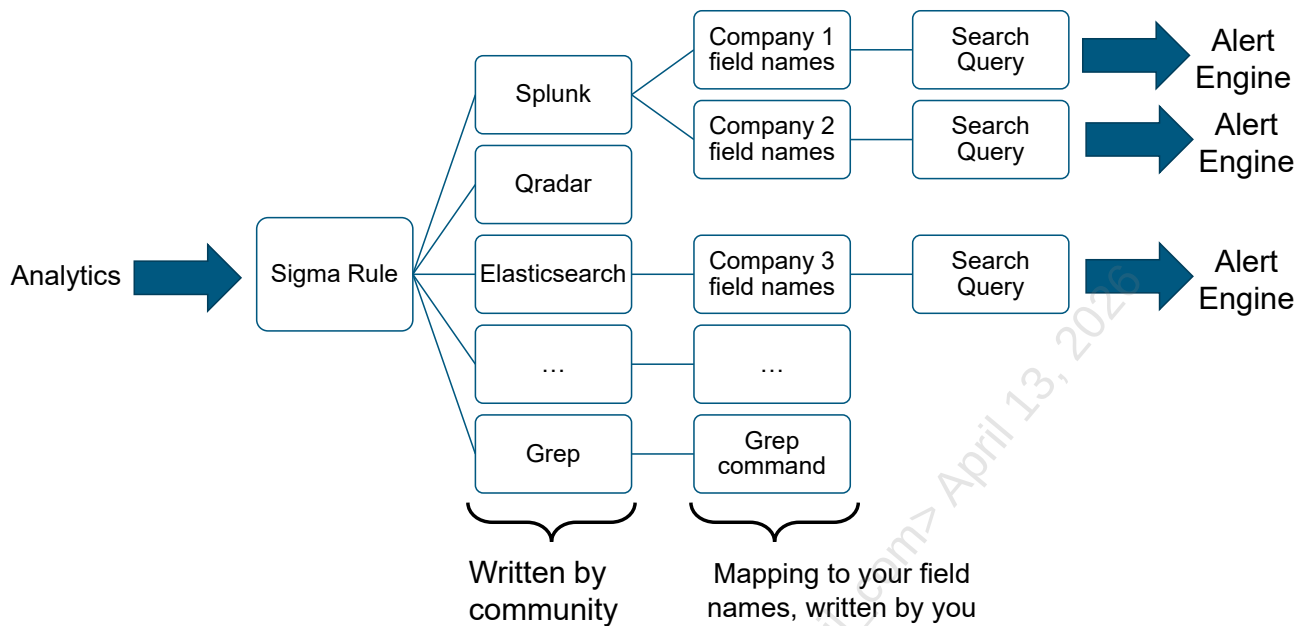


To make Sigma rules work with a SIEM, they must be converted using PySigma or the Sigma CLI. The process looks as follows:

- Write the rule in Sigma format.
- Create a file mapping generic field names to field names within a given SIEM platform.
- Use PySigma or the Sigma CLI tool to convert from Sigma format to a specific SIEM product rule format.

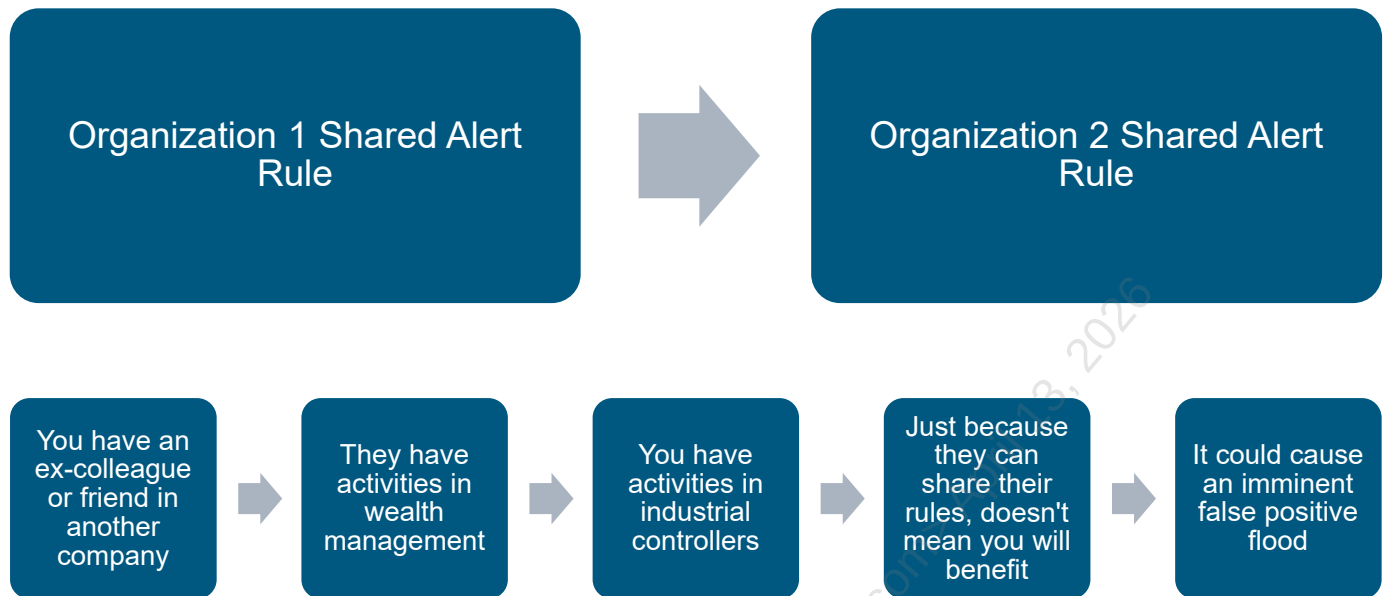
The process is simple and can be automated with basic scripting skills.

From Sigma Signatures to Alert Queries



This slide illustrates the conversion process from the previous slide. There's a tremendous amount of work that has been put in Sigma from the community, so you can use all of that good work as your basis. Once you obtain a rule that caters to the product you are currently using, such as Splunk, then you have to ensure that the field names mentioned in that rule (that has already been developed by passionate security analysts and researchers) are appropriately mapped to the field names you have in your environment, for alerts to properly trigger later down the line.

Sharing Rules



Because Sigma rules are a generic format, they are perfect for sharing. Projects such as MISP make this a simple task. Now, organizations can create custom rules and share them openly with anyone or strategically with specific partners or industries.

However, sharing Sigma rules introduces new problems: A rule that works in one environment may not work well in another. Some rules are intended to be applied based on knowing thyself, while others map to attacker methodologies. Therefore, rules that are shared should go through a quality review.

The point here is that although you mean well, you might end up doing more damage than good. How?

Alert fatigue can ensue. If you just give the SOC 5,000 more alerts, even if 50 of them are great, how will they find those when they will be drowning in a pool of others that offer no real value?

Uncoder.io

The screenshot shows the Uncoder.io web interface. On the left, a Sigma rule is entered in a text area. On the right, the destination format is set to 'AWS OpenSearch Query (Lucene)'. A red callout 1 points to the Sigma rule content, a red callout 2 points to the destination format dropdown, and a red callout 3 points to the 'TRANSLATE' button. A blue callout box contains the text: 'When you change SIEM vendor, translate the rule to the new destination format, and off you go. 😊'.

SOC Prime¹ has created uncoder.io,² which is a GUI (Graphical User Interface) allowing you to input a Sigma rule on the left and just translate it to a different format, depending on which tool you're currently using. It has a very easy-to-use web interface and can convert from Sigma for use in SIEM, PowerShell, and other security products.

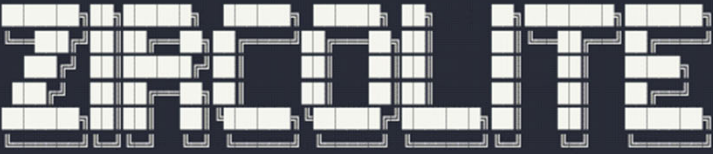
In the above example, the Sigma rule mentioned earlier about the CSharp Streamer RAT has been added and has been converted to a rule that can now be used in AWS OpenSearch query language.

Do note that when using uncoder.io, you're sending your data to a third party. So, if there's anything sensitive, that might be exposed.

An alternative to the above is sigconverter.io,³ which is a community-driven initiative.⁴ It actually was inspired by Uncoder.io and uses pySigma, while Python Flask is used to provide it with its web server capability.

1. <https://sec555.com/1tfj7>
2. <https://sec555.com/mskpd>
3. <https://sec555.com/q0pyw>
4. <https://sec555.com/dklay>

Zircolite



```
-= Standalone SIGMA Detection tool for EVTX/Auditd/Sysmon Linux -=  
  
[+] Checking prerequisites  
[+] Extracting events Using 'tmp-Y0USY355' directory  
100% | 1/1 [00:00<00:00, 5.71it/s]  
[+] Processing events  
100% | 1/1 [00:00<00:00, 4.81it/s]  
[+] Creating model  
[+] Inserting data  
100% | 7346/7346 [00:00<00:00, 37817.78it/s]  
[+] Cleaning unused objects  
[+] Loading ruleset from : rules/rules_windows_sysmon_full.json  
[+] Executing ruleset - 2050 rules  
- Suspicious Remote Thread Target [medium] : 1 events  
- Notepad Making Network Connection [high] : 5 events  
- New Application in AppCompat [informational] : 13 events  
- Bypass UAC Using DelegateExecute [high] : 1 events  
- Rundll32 Execution Without DLL File [high] : 22 events  
- HackTool - Koadic Execution [high] : 9 events
```

Zircolite¹ is a great option for applying Sigma rules to log sources you have available and assessing if an alert triggers. It's based on a Sigma backend, written in Python3, and supports the following log types:

- MS Windows EVTX (EVTX, XML, and JSONL formats)
- Auditd logs
- Sysmon for Linux
- EVTXtract
- CSV and XML logs
- JSON Array logs

It's extremely fast and can go through very large amounts of logs in seconds (depending on how large they are, of course).

1. <https://sec555.com/sdi5o>

Case Management

Case management should support

- Logs per user (ownership)
- Escalation
- Closure codes
- Isolation of incidents from being read by anyone other than security
- Reporting and metrics

Nice to have

- Attach links and files
- Playbook workflows
- Alert grouping
- Group updating/closing
- Detailed notes
- Pivot to relevant data
- Smart actions (automations such as notification via SMS/email/Slack/Teams)

There are various requirements that different organizations have regarding case management tools. Some of the core ones are:

- **Logs per user:** Think of this like an audit trail of what activities an investigator took while working on a case. There should be a full audit trail that you can read and ascertain what has happened.
- **Escalation:** The tools should provide a way for analysts to escalate cases either to different SOC analyst tiers or even to another related team, like incident response, threat intelligence, etc. The ticket should be able to "travel" within different teams so the required elements can provide insight, which is recorded appropriately within it.
- **Closure codes:** Each environment has its own codes, but at a minimum, you need to close out cases as true positives, false positives, true negatives, and false negatives. You can then granulate even further and think about being able to report upon all these fields to provide an ample understanding of cases.
- **Isolation of incident information to only the security team:** Although different security operational teams need to be able to work side by side, no one in the company should have visibility in a security case. Sometimes companies invest a lot of money, for example, buying an ITSM (IT Service Management) tool that everyone can use but that may not be beneficial if there's no proper segregation.
- **Reporting and metrics:** Think about what fields you need to report on and if that is supported or not. For example, what if management asks not only to report on true positive alerts (making their way into incidents) but also what the closure sub-code (or category) is, such as physical theft, denial of service, malware on a server, etc.? Is that doable with your tool?

There are all sorts of nice-to-have features you can consider (like being able to attach files and URLs, group alerts and edit them in bulk, automating actions, and more). Although these are beneficial, they are not showstoppers for any SOC. Strive to get more if you can, but always think about what your core requirements are (the ones you can't live without).

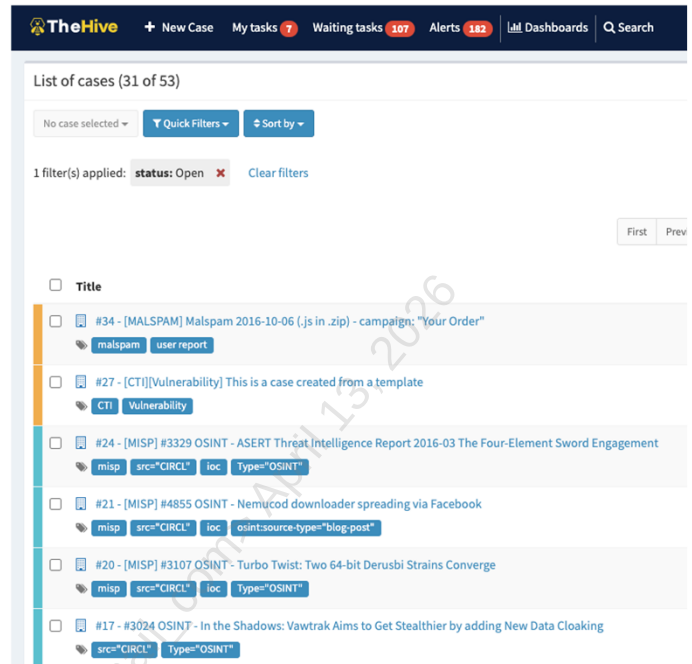
TheHive

Used to be open-source until v4 but from v5 onward is a paid solution

Limited version is fairly constrained

IMS solution = **TheHive** + **Cortex** + **MISP**

- Cases follow steps in a pre-made **case template** (playbooks).
- Cases have **tasks** that need to be completed.
- Tasks have associated **worklogs**.
- Cases can have **observables** assigned to them.
- Observables can be enriched by **analyzers** enabled in **Cortex** engine.



TheHive¹ is a combination of an incident management system (IMS), automatic context analysis and orchestration, and threat intelligence platform. Cortex provides automatic orchestration responses and log enrichment. MISP provides threat intelligence integration. You can even import MITRE TTPs to your alert management function.

The three individual solutions are neatly intertwined to provide a holistic solution for implementing playbooks and performing investigations.

TheHive can:

- Receive alerts from multiple security platforms.
- Provide analysts with notifications over email, Slack chat, API integration to other tools, etc.
- Support a good level of artifact addition into cases, as it allows you to upload IOCs, tag cases, add metrics, and a lot more.
- Allow you to customize levels of access with roles and permissions.
- Streamline analyst work by assigning tasks to analysts.
- Be used on-premises or as a full SaaS solution.
- Allow you to have any IOCs in your cases sent to numerous Cortex analyzers automatically.

1. <https://sec555.com/t8sfe>

Cyphon

Multi-source support (firewalls, log files, and more)

Event categorization

Tool integration provided with API calls

Correlation support by filtering alert data against other data sets

Uses RabbitMQ (message broker) and Logstash (alert aggregation)

Available in Docker container

The screenshot shows the Cyphon Alerts dashboard. On the left, there are filters for Level (Critical, High, Medium, Low, Info), Status (New, Busy, Done), Source (All), Time (Any), and Assigned (All). The main area displays a list of alerts, showing 1-17 of 17. Each alert entry includes a timestamp, source (dss.ids or smokey.mail), a count in parentheses, a description, and an assigned user.

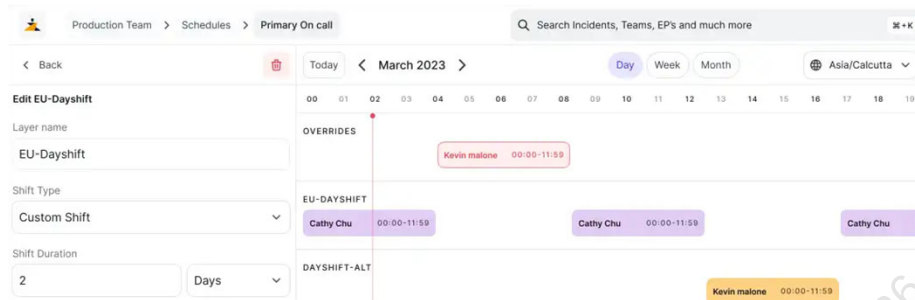
Level	Status	Source	Time	Assigned	Alert Details
Critical	New	dss.ids	03/15/2017 01:20 PM	1	POLICY-OTHER Adobe ColdFusion admin API acc...
High	New	dss.ids	03/15/2017 01:20 PM	1	SERVER-WEBAPP WebTester install2.php arbitra...
Medium	New	dss.ids	03/15/2017 01:20 PM	1	MALWARE-CNC Win.Trojan.Dexter variant ou...
Low	New	dss.ids	03/15/2017 01:20 PM	1	MALWARE-CNC Win.Trojan.Dexter CasinoLo...
Info	New	dss.ids	03/15/2017 01:19 PM	1	SERVER-WEBAPP Drupal RESTWS restws_page...
	New	dss.ids	03/15/2017 11:25 AM	2	POLICY-OTHER Adobe ColdFusion admin API...
	New	dss.ids	03/15/2017 11:25 AM	2	SERVER-WEBAPP WebTester install2.php ar...
	New	dss.ids	03/15/2017 11:25 AM	2	MALWARE-CNC Win.Trojan.Dexter variant ou...
	New	dss.ids	03/15/2017 11:25 AM	2	MALWARE-CNC Win.Trojan.Dexter CasinoLoa...
	New	dss.ids	03/15/2017 11:25 AM	2	SERVER-WEBAPP Drupal RESTWS restws_calib...
	New	smokey.mail	02/26/2017 08:34 AM	1	[**SMOKEY**][CRIT-310] Up2Date prefetch failed
	New	smokey.mail	02/21/2017 11:44 AM	1	[**SMOKEY**][CRIT-861] Advanced Threat Prot...
	New	smokey.mail	02/21/2017 11:14 AM	3	[**SMOKEY**][CRIT-861] Advanced Threat Prot...
	New	smokey.mail	02/21/2017 10:37 AM	2	[**SMOKEY**][CRIT-861] Advanced Threat Prot...
	New	smokey.mail	02/21/2017 10:02 AM	1	[**SMOKEY**][CRIT-861] Advanced Threat Prot...
	New	smokey.mail	02/21/2017 09:15 AM	5	[**SMOKEY**][CRIT-861] Advanced Threat Prot...
	New	dss.ids	01/04/2017 11:55 AM	267	MALWARE-CNC Torpig bot sinkhole server DNS looku...

Cyphon¹ supports the following:

- Multi-source collection of alerts and incident creation.
- Provides automatic data enrichment, such as adding IP geographical information.
- Categorization, grouping, and prioritization of alerts.
- Numerous tools can be integrated using API calls.
- Apart from incident management, the tool can also be used for social media monitoring.

1. <https://sec555.com/ynb61>

Zenduty



Playbook support

Really good interface and support for on-call schedules

Great integration with notifications over Slack, Teams, and other external tools

Supports great metric variety

Ability to provide stakeholder notifications about incident progress

Supports postmortem reporting

Zenduty¹ is also worth noting due to its rich integration collection² and the ability to support on-call scheduling. That feature is tremendously helpful for operations teams in medium to large-scale environments. Usually, they need a third-party tool to do this, which can be very challenging to seamlessly integrate.

Not only that, but it's able to provide escalation notifications via a variety of platforms, like SMS, Teams, Slack, email, Android, and iOS notifications.

It's also able to support integrations with additional ITSM tools, like ServiceNow, Statuspage, Jira, and Zendesk, which are commonly used by IT and operations teams in numerous environments.

1. <https://sec555.com/sloet>
2. <https://sec555.com/e8qgn>

Summary

A SIEM can greatly augment the operational efficacy of any given organization. Good detection content makes a huge difference. Ensuring prompt alert investigation, tuning, and use of tools like Sigma (allowing content to be usable, even if you change tools) are extremely important to identify malicious activity promptly.

This area is intentionally left blank.

Identify Log Gaps and Compare with Sigma Coverage

Refer to the lab workbook for instructions.

This area is intentionally left blank.

Course Roadmap

Section 1: Detection Engineering and SIEM Architecture

Section 2: Network and Endpoint Analysis

Section 3: Asset Discovery, Baselines, and UEBA

Section 4: Cloud Logging and Monitoring

Section 5: Alerting and Detection Engineering Pipelines



- SIEM Alerting and Analysis
 - ☐ Lab 5.1: Identify Log Gaps and Compare with Sigma Coverage
- Post-Mortem Analysis and Detection Engineering Pipelines
 - ☐ Lab 5.2: Using VirusTotal for Malware Detection and Removal

This area is intentionally left blank.

Module Objectives



The student will understand the value of reanalyzing existing logs and working with detection engineering pipelines.

This area is intentionally left blank.

Too Much Data?

At the end of the day, you have copious amounts of data

- Longevity is often for compliance or incident handling
- There's value in reanalyzing data with different insight than what you had 1 month ago

Better to find something tomorrow than never

- Requires a valid detection technique

Every day, billions upon billions of logs are saved. These logs then sit there and do nothing. They wait for a compliance report to be run or an incident that requires searching back in time. Conceptionally, it seems like they are yesterday's news and of little value.

But this is hardly the truth. Old data is still alive and kicking. It just needs a valid use case, of which there are multiple. Reanalyzing old data can help find unauthorized connections or malware that was not detectable the day it happened.

What's the Value of Reanalyzing?

Why?

It may not be possible to detect something today.

- Zero-day today, known malware tomorrow.

Some techniques require advanced software or historical data.

- Machine learning may analyze newly received data.
- It may analyze historical data (same with scripts).

So, how can old data catch things today when it did not yesterday? Part of this is because a lot of security capabilities still rely on signatures. Take antivirus as an example; a signature may not exist today that evil.pdf is malicious. Yet as evil.pdf gets spread and caught, signatures are developed. Rescanning the same file later is likely to be identified as malicious.

The same concept applies to SIEM data. Threat intelligence feeds are, in effect, signatures. Rescanning information using feeds can identify old connections that were malicious. Other non-signature-based techniques can also apply math algorithms against historical data to find trends and patterns.

Signature Detection

Signatures used to identify known bad actors

- AV uses signatures to analyze files and file hashes
- Intel threat feeds used to identify other bad indicators

SIEM is full of data that can be used with signatures

- No signature today but maybe tomorrow

IP addresses

////

Hashes

////

Domain names

////

URLs

////

Email addresses

////

User-Agents

////

Any data contained in threat intelligence feeds can be rescanned. IP addresses, domain names, and URLs are probably the most common. Depending on what data you are collecting, you may also have hashes that can be checked on an ongoing or historical basis for malware. Typically, this involves submitting hashes to antivirus programs.

A common example is using a resource like VirusTotal.¹ When a malicious file is very new, there are often no hits. But gradually, as more and more antivirus engines from various vendors pick up on the file, the detection rates increase. You could do an API call to VirusTotal now and have zero detections, but then use the same artifact tomorrow and get 40.

1. <https://sec555.com/mf2tq>

Hash Check

Multiple log sources of hashes:
AV logs, Application Control
logs, Zeek, Suricata

- SIEM database provides means to query all hashes

This can be used to recheck for
known bad hashes

- Requires scripting and automation or aggregator

sha1

e072c23f209cd7c43013f0d46e610dd68ab41edc

948e1652586240d453287ab69caeb8f2f4f02117

054d03c8ce3da257c954a852a103c7d04dd831bf

91f5ed437e7b97a46af09da9d950b3aacf891360

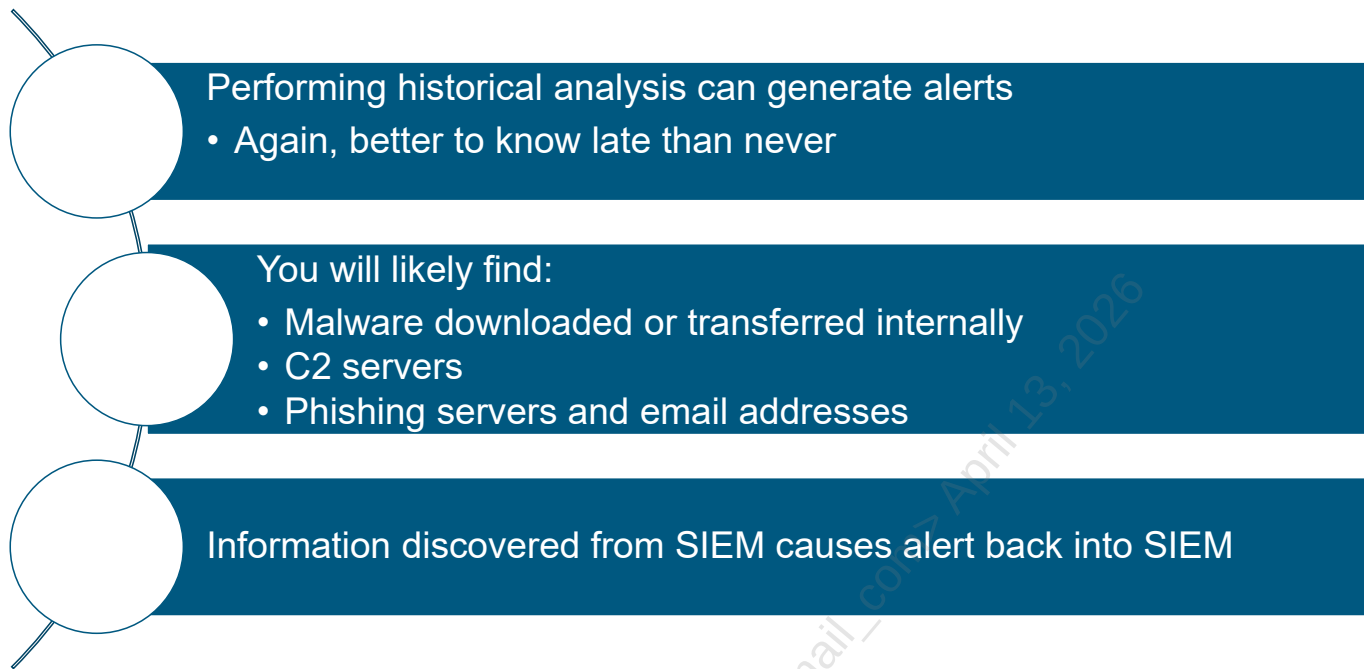
Copies of last night's/week's
hashes for checking again
today

This slide represents pulling back a list of hashes from the previous day's logs. One thing that makes this a bit more difficult is that a SIEM is not a one-stop shop. You may have hashes spread out across multiple data sources. First, you need to identify which data sources you want to use. This may include all of them, just a few, or maybe even one.

The next step is equally important. How do you want to retrieve and analyze this data? This could be done with a script or, in some instances, can involve using the log aggregator to re-ingest old logs.

Note that to do the above, there's an assumption that you are collecting hashes with at least one of your log sources. If you are not, then this won't work.

Historical Data Alerts



Using scripts or the log aggregator pipeline to reanalyze data is likely to find multiple types of unauthorized or malicious items. The trick is to perform the analysis and then trigger logs or alerts to investigate. This means an incident may be declared after more than 24 hours have gone by. While less than ideal, it is better than never finding it at all.

Remember, the adversary does not win until they complete their goals. A full day, or even weeks, will not always be enough time for them to do so.

Detecting Beacons with Historical Data



Historical connections can be used to identify C2.

- Malware may phone home every day at 2:00 a.m.
- May phone home every 5 minutes



It can be hard to catch due to minimal duration/size.

- Difficult to treat a single connection as evil
- Trends over time are possible



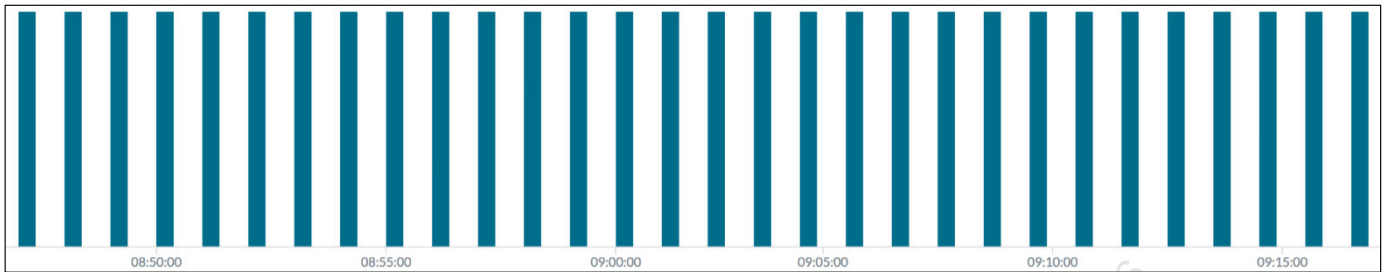
Trending + Log data = Identified C2 beacons



An area where historical data creates some high-value-added detection mechanisms is the use of connection logs to identify beaconing. Beaconing is when an infected system checks in at regular intervals or within a pattern of activity to a command and control server. This activity can be difficult to catch.

However, looking at all the connections that systems make and then applying data analytics against them provides a unique opportunity to catch this.

Beacon Visualization



The visualization shows the connections of two systems plotted on a graph.

Internal system is constantly talking to an external system.

- And the time between connections is **exactly** the same.

This page demonstrates what a beacon looks like graphically. This was taken from a live network and represents a single system connecting to a single destination. The time interval between connections is exactly the same and is ongoing. This is an example of beaconing. Where things get a little muddy is that this does not necessarily mean beaconing is malicious. Certain systems check into a central server at regular intervals by intent.

Visually, it is easy to distinguish a pattern. The problem is how to do this at scale and automatically. Fortunately, math algorithms and checks can be used to identify beaconing.

Flare

Austin Taylor wrote a beacon discovery script called **Flare**.¹

- Uses Elasticsearch to crawl historical connections
- Identifies connections with consistent beaconing
- Supports analysis of custom time periods
 - Last 24 hours (default behavior)
 - Last X days (to find single beacon per day activity)
 - Larger time frames supported

It's an ongoing project—new capabilities are being developed all the time.

Austin Taylor, a cybersecurity enthusiast and experienced data science subject matter expert, developed a Python script called Flare.² It is publicly available on GitHub and is primarily focused on identifying beacons in historical network connections. It pulls data out of Elasticsearch, then tracks communication from every source IP address to every destination address, then uses math to identify beaconing patterns. The script can and should be modified to look for different types of beacons.

The default behavior is to look for beacons within a 24-hour period, such as a device checking in every 5 minutes. To look for beacons that check in once a day, the time frame parameter needs to be adjusted to look further back in Elasticsearch. This is an ongoing project and subject to change any added features.

1. <https://sec555.com/28vsz>

2. <https://sec555.com/28vsz>

Flare Output

The output shows 192.168.0.20 talking to 52.20.116.172 every five minutes.

- And data is regularly being transferred

percent	interval	src_ip	dest_ip	dest_port	bytes_toserver	src_degree
47	299	192.168.0.20	52.20.116.172	443	129588	1

The intention is to run the script once a day.

- Investigate output and filter out false positives

In this page, the picture shows the output from Flare. In it, the device at 192.168.0.20 has been identified as talking to 52.20.116.172 every 299 seconds (roughly five minutes). It has also identified that the percentage of traffic going to 52.20.116.172 is 47 percent, with 129,588 bytes. Identifying sources and destinations for beacons is step one. Step two is investigating the connections to see if they are legitimate or malicious in nature.

This script is designed to run once a day and, likely, with multiple sets of parameters. For example, the default parameters may be used to find short-span beacons within a 24-hour period. A larger time frame may be used to look for beacons that occur once a day.

Below are descriptions of some of the columns in Flare's output:

- **percentage** is based on how much traffic is going toward the beacon destination.
- **src_degree** is the number of devices internal to your network that have communicated with the destination IP address.
- **interval** is the time interval between check-ins.

Various SIEM tools today offer options to uncover beacons. For instance, Elastic has a network beaconing transformation available to that end.¹

1. <https://sec555.com/9a2fu>

Performance Considerations

Post data analysis involves pulling back lots of logs.

- Requires lots of CPU and lots of memory
- Data calculations likely to cause CPU to run at 100%

Because of this, be careful where post-analysis runs.

- Log aggregator systems = bad idea
- Backend storage systems = bad idea
- Reporting systems = not perfect
- Dedicated VM or server = good idea

Because looking for beacons requires lots of math calculations and buffering data in RAM, it is resource-intensive. Keep in mind, resource-intensive does not mean expensive and out of reach. Mainly, it means that when running analysis, it is likely to consume 100% CPU and plenty of RAM. This could be for a few minutes or maybe even a few hours. Because of this, you do not want it running on critical infrastructure. The best location is likely on a dedicated VM.

Even if you are in a large environment, the cost of having a physical dedicated analysis box is likely to be considered cheap. CPU and RAM are becoming cheaper and cheaper every year. Cloud clusters are also there to assist. During analysis, your cloud VM will use all CPU and memory; however, when it is complete, it will use almost nothing.

Used equipment could also be a great candidate for this, as the focus is on detection and is not strictly speaking mission-critical. Plus, if the used equipment breaks, you can buy more used equipment, and the logs will be there waiting for analysis.

Post-Mortem Analysis via Logs

Logs on disk can be used for post-mortem checks

Can distribute load while still sending alerts to SIEM

Real Intelligence Threat Analytics (RITA) uses Zeek logs

Maintained by Active Countermeasures

Discovers beacons, unauthorized systems, and scanning

It is also possible to perform post-analysis using raw logs rather than pre-ingested SIEM data. For example, RITA was designed to analyze Zeek logs. It can be run in a distributed fashion, and reports or alerts can be sent to the SIEM.

Not all data has to be centralized. The same holds true with post-mortem analysis. Where centralization helps is with analysis capabilities in a single spot. How data is processed is not as important, short of how easy or difficult it is to maintain.

Reference:

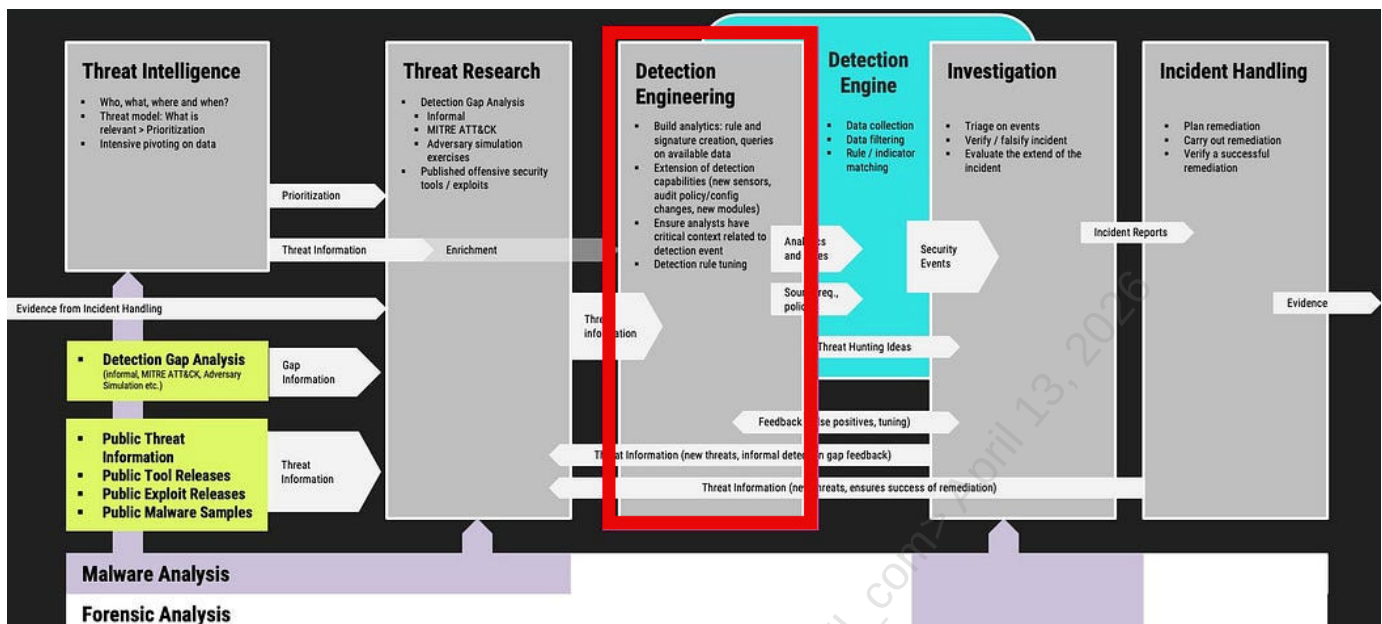
- <https://sec555.com/cdmi7>

Detection Engineering Pipelines



This area is intentionally left blank.

Detection Engineering Fit



If you're still wondering about the value of detection engineering as a function within an environment, and how it fits with other roles, look at the above diagram.

- Detection engineering in security monitoring: Responsible for obtaining threat-related data and ingesting it into a SIEM or other detection tool.
- Detection engineering in incident response: IOCs enrichment, YARA rule creation.
- Detection engineering in malware analysis: Obtaining IOCs and translating them into YARA rules from a compiled malware analysis report.
- Detection engineering in threat intelligence: YARA rule creation for actor toolset/phishing documents tracking in online platforms like VirusTotal.
- Detection engineering in digital forensics: Create rules for case-related elements that have been extracted during the course of host forensics (e.g., registry modifications, file hashes, etc.).

In short, not only can an environment greatly benefit from having a team solely dedicated to detections, but it would be something highly recommended. You can make this part of your current team's workload (e.g., SOC or incident handlers), but there's too much work to be done as a side job, and it will most likely fail if approached like that.

Reference:

- <https://sec555.com/8qd04>

Image reference:

- <https://sec555.com/8qd04>

Traditional Detection Creation

Traditional Detections

- Lack of accountability for rules changing
- Lack of version control
- Inability to reuse content
- Lack of updates on rule creation progress
- Inability to ensure consistent rule deployment
- Lack of automated rule verification capability
- Unable to consistently meet quality

What are some challenges with traditional detection creation methodologies?

- **Lack of accountability:** A rule changed in a tool. Do you always have the ability to identify who performed that change, when, and what exactly was done?
- **Lack of versioning:** In a traditional (non-CI/CD-enabled) environment, there is no real way to ensure content changes are tracked throughout time.
- **Inability to reuse content:** Content is commonly tied to specific vendors and tools, so it makes it much harder to be able to reuse it if those are not present anymore.
- **Lack of updates:** There is no consistent way of knowing what is the progress of a new detection rule that was asked to be created. Has that rule creation even been approved? Is it happening now, in two months, or never?
- **Consistent rule deployment:** If there's no main tool used to create and push new content in the environment, there can be numerous inconsistencies created, which makes maintenance a very big problem.
- **Manual verifications required:** When developing new content, it usually requires significant manual labor to test it and ensure it works as intended before deploying it.
- **Quality inconsistency:** If there are no set criteria that have to be met by requests for new content and associated implementation of those requests, then there's no guarantee that our detection content will be pristine. It also makes quality assurance more difficult.

Automating Detection Engineering

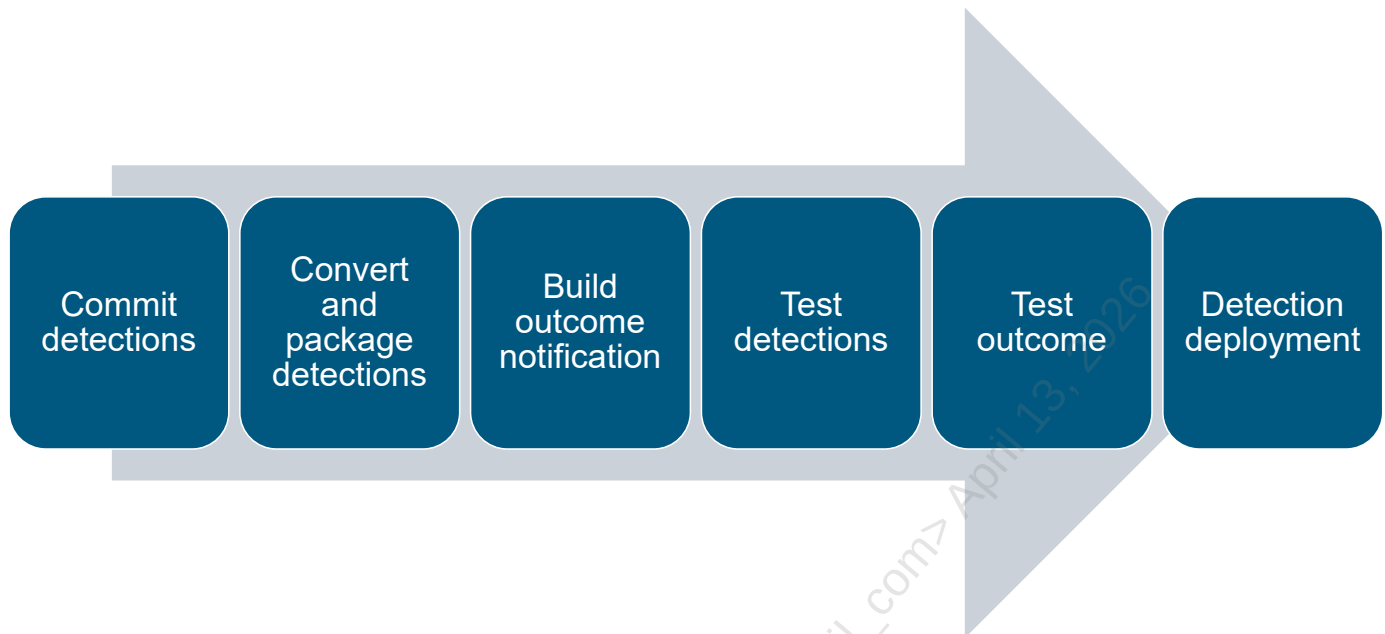
Benefits

- Maintain content versioning
- Decouple content from specific vendors or tools
- Speed
- Collaboration
- Staying current with attacker techniques
- Testing attacking methodologies
- Automatic content validation

What does automating our Detection Engineering function give us?

- **Content versioning:** One of the fundamental building blocks of automation is versioning control. It allows you to track any changes and also promotes peer reviews to be performed on your content.
- **Decouple content from specific vendors or tools:** Any detection content being developed can use an underlying schema (e.g., YAML or JSON) to ensure that your work can be transferable in case you change your current vendors or toolstack.
- **Speed of operations:** Using automation at scale, like the level achievable by using a CI/CD pipeline, can allow faster detection, development, testing, and deployment.
- **Collaboration:** Multiple detection engineers and other teams can provide feedback and use our rules since any CI/CD pipeline allows you to fork the main repository and make changes, which can then be committed to the main branch.
- **Staying current:** Ensuring to integrate with detection rule projects (discussed later in this module) gives you the ability to consume content already vetted by the security industry, which continuously gets updated to keep you up-to-date.
- **Testing attacking methodologies:** You can include the automatic deployment of a testing infrastructure for your use cases to be tested but also to simulate attacker activity with adversary emulation tools.
- **Automatic content validation:** You can build test cases based on log events and ensure the detection content is validated against them. This can happen:
 - Statically: Using pre-defined test cases against your detection rules.
 - Dynamically: Running detections against real data.
 - Continuously: Performing automated testing in a live environment.

CI/CD Detection Workflow



The CI/CD detection workflow presented on this page was created by Splunk and allows you to automate detection content creation, testing, and deployment.¹ The tools it uses are CircleCI² as a CI/CD tool (which can be automated with GitHub) and Splunk security content as a detection rule source.

- **Commit detections:** At this phase, we need to ensure that we automate the collection of content, which will be the basis for our later detection rules. There are numerous detection project options available (examples are mentioned on the next page). Ensure you choose a code repository (e.g., GitLab³ or GitHub⁴) for easy versioning and later deployment. Another advantage of doing that is that multiple teams can contribute to your detection content (e.g., threat hunters, incident responders, and malware analysts) since they can branch out, make modifications, and then merge changes to the main branch.
- **Convert and package detections:** Now that you have detections available, in this phase, you will convert them from their native schema (like YAML) to something that a SIEM can use (like a SIEM search that can be run on a schedule). It's important to use a tool supporting a native schema (like Sigma or Splunk security content, both supporting YAML) so your rules are decoupled from being tied to any specific SIEM tool.
- **Build outcome notification:** Validation scripts can be run against what was packaged in the earlier stage to verify that appropriate components are present in the detection content.
- **Test detections:** The focus is on continuous content testing. Building a lab environment for the detection engineering team is required. Ideally, you need to approach the actual production environment as much as possible. You will also need attacker emulation tools, like Caldera⁵ or Atomic Red Team⁶ scripts, to simulate attacks. Any output generated will end up in logs, which can be used to validate the operation of current detections or create new ones. This can happen each time you look at a new detection.
- **Test outcome:** Represents the attack outcome. Either successful or not.
- **Detection deployment:** There are three main ways to deploy detections:
 - Package detections into an application (which is something feasible via the CI/CD pipeline tool)

- Forking the project from a Git repository
 - Using a REST API to request the detection content
1. Detection as Code: Detection Development Using CI/CD (<https://sec555.com/tdp20>)
 2. <https://sec555.com/4a9s5>
 3. <https://gitlab.com/>
 4. <https://sec555.com/10stk>
 5. <https://sec555.com/xvgzj>
 6. <https://github.com/redcanaryco/atomic-red-team>

Licensed To: Arvind Pariti <paritiarvind@gmail_com> April 13, 2026

Detection Rule Repositories

Choose a basis for your detection content



Select one with a defined schema (e.g., supporting YAML)

Splunk Security
Content (Splunk)

Threat Hunter
Playbook

Detection Rules
(Elastic)

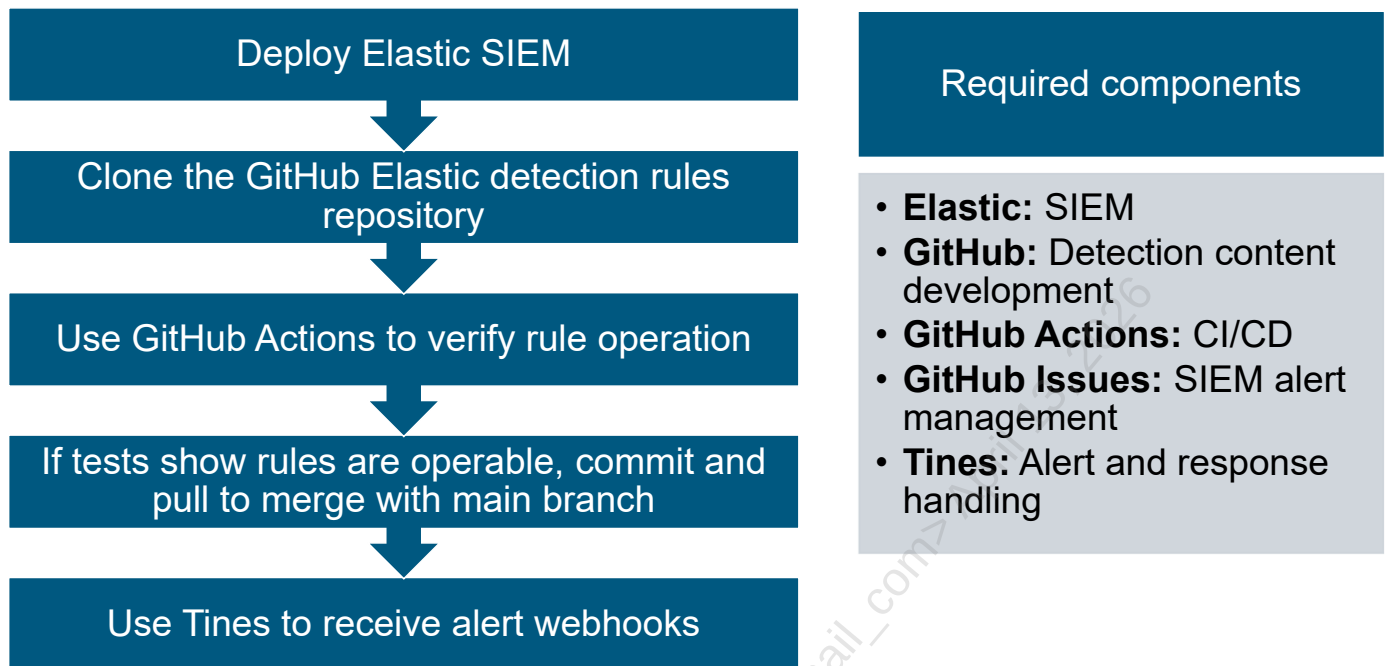
Yara Rules

Since the purpose is to automate detection creation, it would be great if we could use content from a project that already contains detections we can use. We already explored Sigma, which can be one potential source. A few other ones include:

- **Splunk Security Content:**¹ Contains all the Splunk detections which are used in Splunk's ES (Enterprise Security) SIEM.² They have been created by Splunk's threat research team, and they have been available as an open-source project since 2019. This is what the previously mentioned CI/CD workflow used.
- **Threat Hunter Playbook:**³ Open-source resource that follows the MITRE ATT&CK framework and allows detection logic sharing. It uses Jupyter notebooks for content sharing.
- **Detection Rules:**⁴ Contains all the Elastic Security detection rules, which can be used for developing, maintaining, testing, validating, and releasing rules for Elastic's detection engine.
- **Yara Rules:**⁵ Public repository of Yara rules, which can be used for integration and implementation of detection content.

1. <https://sec555.com/mas5z>
2. <https://sec555.com/bp28x>
3. <https://sec555.com/xqznj>
4. <https://sec555.com/w021k>
5. <https://sec555.com/wv9sy>

Case Study: Tines



There's an interesting automation for Detection Engineering presented by Tines. It uses the following:

- **Elastic SIEM** as a source of detection rules.
- **GitHub** for detection development.
- **GitHub Actions** as a CI/CD tool.
- **GitHub Issues** as a SIEM alert management tool.
- **Tines** for alert and response handling.

A high-level summary of the required steps follows:

1. Deploy Elastic SIEM, either on-premises or use their cloud option.
2. Clone the Elastic rule repository to create a new version of it, so you can create new rules. Ensure that you also create a new directory to store your rules within the cloned repository.
3. GitHub Actions should be configured to test the operation of new rules, to ensure they have been created appropriately and will be able to work in Elastic SIEM.
4. After all the checks are run and the new detection rule's operations are verified successfully, then it can be merged into the main GitHub code branch.
5. Use Tines to receive alerts via a webhook with Elastic SIEM and follow a story, which should make each new alert result in a new GitHub issue ticket.

Reference:

- <https://sec555.com/b5es0>

LLM/GenAI for Detection Building



The next slides will look at using an LLM/GenAI model to build detections.

Disclaimer: The next series of slides has been generated using ChatGPT so that we can experiment with how an AI-assisted approach can be taken. As such, success is not guaranteed.

AI Assisted Detection Engineering

ChatGPT ▾

How can I create an automated detection engineering pipeline ?

Sample Tools/Tech Stack

Layer	Tools
Version control	Git, GitHub, GitLab
Rule format	Sigma, YARA, SPL, KQL
CI/CD	GitHub Actions, GitLab CI, Jenkins
Testing	Atomic Red Team, Caldera, logreplay
SIEM/EDR Integration	Splunk API, Sentinel ARM, Elastic API
Alert review	Jupyter, Splunk Dashboards, SIEM review tools

Would you like a code example or GitHub Actions pipeline to get started with? Or want me to help you build this around a specific tool like Splunk, Sentinel, or Elastic?

📄 🗑️ 🗑️ 🗑️ 🗑️ 🗑️

Initially, the author asked ChatGPT how to create an automated detection engineering pipeline. A large response was provided (which has been trimmed here for clarity), and, at the end, tools were proposed to be used.

A suggestion was even provided from ChatGPT to help build this around a specific tool, like Splunk, Sentinel, or Elastic. An option was made for Sentinel (since you already saw it in action earlier in the course).

Build for Sentinel

Sentinel Detection Engineering Pipeline (Automated via GitHub Actions)

We'll build a basic pipeline using:

- Sigma rules as source
- GitHub Actions for CI/CD
- Conversion to KQL
- Testing (optional)
- Deployment via Sentinel API / ARM templates

Project Structure Example

```
bash
sentinel-detections/
├── detections/
│   ├── initial_access/
│   │   └── suspicious_ip_connection.yml
│   └── persistence/
│       └── registry_autorun_key.yml
├── kql/
│   └── initial_access/
│       └── suspicious_ip_connection.kql
├── testdata/
│   └── suspicious_ip_connection.json
├── .github/
│   └── workflows/
│       └── detection-ci.yml
└── deploy/
    └── suspicious_ip_connection.json # Sentinel ARM JSON
```

ChatGPT provided the project structure by yielding the following components:

```
sentinel-detections/
├── detections/
│   ├── initial_access/
│   │   └── suspicious_ip_connection.yml
│   └── persistence/
│       └── registry_autorun_key.yml
├── kql/
│   └── initial_access/
│       └── suspicious_ip_connection.kql
├── testdata/
│   └── suspicious_ip_connection.json
├── .github/
│   └── workflows/
│       └── detection-ci.yml
└── deploy/
    └── suspicious_ip_connection.json # Sentinel ARM JSON
```

GitHub Actions Workflow

Step-by-Step: GitHub Actions Workflow

Here's a GitHub Actions YAML workflow to:

1. Validate Sigma rules
2. Convert Sigma → KQL
3. Deploy to Sentinel

◆ `.github/workflows/detection-ci.yml`

It proceeded with generating a full GitHub actions workflow:

```
name: Sentinel Detection CI/CD
```

```
on:
```

```
  push:
```

```
    paths:
```

- 'detections/**/*.yaml'
- '.github/workflows/**/*.yml'

```
  pull_request:
```

```
jobs:
```

```
  build-deploy:
```

```
    runs-on: ubuntu-latest
```

```
    steps:
```

- name: Checkout repo
 uses: actions/checkout@v3
- name: Set up Python
 uses: actions/setup-python@v4
 with:
 python-version: '3.10'
- name: Install Sigma tools
 run: |
 pip install sigmatools

```

git clone https://github.com/SigmaHQ/sigma.git
cd sigma/tools
pip install -r requirements.txt
- name: Convert Sigma to KQL
  run: |
    mkdir -p kql
    for rule in detections/**/*.*.yml; do
      base=$(basename $rule .yml)
      mkdir -p kql/$(dirname $rule | cut -d '/' -f2)
      python3 sigma/tools/sigmactool -t microsoft/sentinel $rule -o
      kql/$(dirname $rule | cut -d '/' -f2)/$base.kql
    done
- name: Deploy to Sentinel (Preview)
  env:
    AZURE_CREDENTIALS: ${ secrets.AZURE_CREDENTIALS }
  run: |
    echo "$AZURE_CREDENTIALS" > azure.json
    az login --service-principal --username "$(jq -r .clientId
    azure.json)" \
      --password "$(jq -r .clientSecret azure.json)" \
      --tenant "$(jq -r .tenantId azure.json)"
    for file in deploy/*.json; do
      az deployment group create \
        --resource-group <YOUR_RG_NAME> \
        --template-file $file \
        --parameters workspaceName='<YOUR_WORKSPACE_NAME>'
    done

```

GitHub Config and Unit Testing

Required Secret:

In GitHub:

- Set `AZURE_CREDENTIALS` (from an [Azure SPN](#)) as a secret.

```
bash
az ad sp create-for-rbac --name "sentinel-cicd" --role contributor \
  --scopes /subscriptions/<sub-id>/resourceGroups/<rg-name> \
  --sdk-auth
```

(Optional) Detection Unit Testing

Want to add auto-tests?

You can:

- Simulate logs in `testdata/`
- Write test scripts to assert whether the converted KQL rule hits your test logs (maybe using KQL + `datatable()` or a test Sentinel workspace)

Let me know if you want help building a test harness like this.

It also provided the required GitHub configuration:

```
az ad sp create-for-rbac --name "sentinel-cicd" --role contributor \
  --scopes /subscriptions/<sub-id>/resourceGroups/<rg-name> \
  --sdk-auth
```

And it mentioned optional support for unit testing on the code.

DECEIVE: An AI-Driven Honeypot



Automatic generation of session summary

Overall session evaluation (benign, suspicious or malicious)

Developed on macOS 15 but aims to also run on Linux/Unix and Windows systems

Currently, only simulates a Linux server reachable via SSH

Log output is .JSON

In early 2025, Splunk announced the arrival of the first AI-driven honeypot, DECEIVE (DECEPTION with Evaluative Integrated Validation Engine).¹

Note that this is a proof of concept and not currently meant to be used in a full production deployment.

For now, it only supports SSH connectivity, but it has some interesting features.² For example, after interacting with it, a summary of the session is provided. It is also able to evaluate what has taken place and provide an overall verdict as to whether this was benign or malicious activity.

It is, of course, a work in progress, but some promising features are currently present.

1. <https://sec555.com/y0jwn>
2. <https://sec555.com/8g7wt>

Summary

Analyzing attack data and performing log investigation at a later time can allow you to benefit from finding malicious patterns that weren't detectable as such at an earlier point in time.

Automating the creation of detection rules using specific frameworks and a CI/CD pipeline can go a long way to reducing fatigue and making powerful detections materialize in a very short amount of time. Coupled with automatic validation, it can give any security function a great advantage.

This area is intentionally left blank.

Using VirusTotal for Malware Detection and Removal

Refer to the lab workbook for instructions.

This area is intentionally left blank.

Contacts and Resources

AUTHOR

Nick Mitropoulos

nick.mitropoulos@scarlet-dragonfly.com

@NickMitropoulos

www.linkedin.com/in/nickmitropoulos

Nick is the CEO of Scarlet Dragonfly, a company that handles a range of security services like SOC, incident handling, and vulnerability management, to name a few. He has over 16 years of experience in various industries, including consulting, education, telecommunications, healthcare, investment banking, financial, energy, oil and gas, insurance, pharmaceutical, law, military, and news. His breadth of experience, combined with his love for teaching, is crucial in helping his students better grasp the various facets of security.

Nick started collecting hacking newspaper articles back in the 80s when security was just starting to grow, and he was immediately hooked. He is a certified ISC2 instructor and a GIAC advisory board member, and he has an MSc (with distinction) in Advanced Security and Digital Forensics from Edinburgh Napier University and a BSc (with distinction and the highest held graduation grade of the department) from the Technological Educational Institute of Thessaly. He is also a faculty member of the SANS Technology Institute, an NSA Center of Academic Excellence in Cyber Defense, and a multiple winner of the National Cyber League competition. Nick has a great passion for teaching and has trained many individuals in a variety of security topics, mainly focusing on SIEM, security operation centers, incident response, and security certification courses.

Nick has worked for a variety of companies (including the Greek Ministry of Education, AT&T, F5 Networks, JP Morgan Chase, KPMG, and Deloitte) and has provided critical advice to many clients that want to improve their current security posture by creating new security operation centers and protocols, developing vulnerability management programs, managing third parties and security vendors, testing incident handling and forensic teams, redesigning perimeter security solutions, and developing custom-tailored training courses for company staff and specialized security teams. One of the greatest challenges for most security professionals is ensuring they have an in-depth understanding of all fundamental concepts of security. Nick loves teaching classes that help students obtain the knowledge required to secure their environments and enhance their personal security posture to protect themselves in an ever-growing digital arena.